

PES UNIVERSITY, BANGALORE

Department of Computer Science and Engineering

SOFTWARE ENGINEERING – LEVEL 3 MINI-PROJECT · UE24CS341A

Mini-Project Deliverables Part-1

Collaborative Study Material & Quiz Platform

Software Requirements Specification (SRS) · Software Architecture & Design Specification (SAD) ·
Software Test Plan (STP)

Item	Details
Group / Team	Group 1 · Team 1
Course / Semester	UE24CS341A – Software Engineering · V Semester
Methodology	Agile (iterative, sprint-based) · MERN stack
Documents	SRS v1.2 · SAD v1.0 · STP v1.0 (document versions; all describe software release 1.0)
Repository	github.com/bharat06-co/SE-Level-3-Collaborative-Study-Material-Quiz-Platform
Date	02-10-2026

Member	SRN	PRN	Owned functionality
Anisha Nukul Niranjan	PES1UG24CS064	PES1202402163	User accounts & profiles (SF-1)
Aryaroop Bose	PES1UG24CS087	PES1202400286	Study material management & moderation (SF-2)
Ayush Ravindra Paithankar	PES1UG24CS104	PES1202400033	Quiz creation, management & leaderboard (SF-3)
Bharat V Bhat (Team Lead)	PES1UG24CS113	PES1202403301	Quiz attempts, scoring & progress analytics (SF-4)

Contents

Software Requirements Specification (SRS)	3
1. Introduction	4
2. Overall description	5
3. External interface requirements	6
4. System features (detailed)	7
5. Non-functional requirements (detailed)	10
6. Quality attributes & Acceptance tests	13
7. System models and diagrams	13
8. Requirements Traceability Matrix (RTM)	17
Software Architecture and Design Specification (SAD)	19
1. Introduction	19
2. Document Overview	19
3. Architecture	20
4. Design	26
5. Appendices	35
Software Test Plan (STP)	36
1. Introduction	36
2. Test Items	36
3. Features to be Tested	36
4. Features Not to be Tested	37
5. Test Approach / Strategy	37
6. Test Environment	38
7. Test Schedule	39
8. Test Deliverables	39
9. Roles and Responsibilities	39
10. Risks and Mitigation	39
11. Assumptions & Dependencies	40
12. Suspension & Resumption Criteria	40
13. Test Case Management & Traceability	40
14. Test Metrics & Reporting	50
15. Approvals	50

Software Requirements Specification (SRS)

Collaborative Study Material & Quiz Platform

Field	Details
Project	Collaborative Study Material & Quiz Platform
Version	1.2 (supersedes v1.1 submitted in Submission 2)
Authors	Anisha Nukul Niranjana, Aryaroop Bose, Ayush Ravindra Paithankar, Bharat V Bhat (Team Lead)
Group / Team	Group 1 / Team 1 · UE24CS341A Software Engineering · V Semester
Date	02-10-2026
Status	Baselined for Submission (Deliverables Part-1)

Revision history

Version	Date	Author	Change summary	Approval
1.1	Submission 2	Team 1	IEEE 830-style SRS: user classes, contributor privilege, FR-001–FR-035, NFR-001–NFR-008, SEC-001–SEC-008, ER model, field layouts, initial RTM.	Submitted
1.2	02-10-2026	Team 1	Restructured into the course SRS template; added acceptance criteria and test case references to every requirement; added security objectives (§5.1.1); added a second UML use-case diagram; made FR-001, FR-014, FR-031, FR-034 and FR-035 measurable; at least 8 test cases per use case; RTM now links to SAD and STP.	Baselined

Approvals

Role	Name	Signature / Email	Date
Course Coordinator / Faculty	Dr Sapna V M		
Team Lead	Bharat V Bhat		

Table of Contents

1 Introduction.....	4
2 Overall description.....	5
3 External interface requirements.....	6
4 System features (detailed).....	7
5 Non-functional requirements (detailed).....	10
6 Quality attributes & Acceptance tests.....	13
7 System models and diagrams.....	13
8 Requirements Traceability Matrix (RTM).....	17

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional and security requirements of the Collaborative Study Material & Quiz Platform, version 1.2. It is the authoritative reference for the Software Architecture & Design Specification (SAD) and the Software Test Plan (STP) in this submission, and is the root of the Requirements Traceability Matrix (RTM).

1.2 Scope

The platform is a responsive web application. Students can search and browse study material, rate and comment on it, attempt topic-linked quizzes with automatic scoring and immediate feedback, and track their progress on a dashboard and a leaderboard. Students with contributor privileges and educators can also upload, organise and share material and create quizzes. Administrators manage roles and privileges and moderate reported material.

In scope	Out of scope
Registration, login, logout, password reset, role-based profiles	Real-money payments / subscriptions
Study material upload, tagging, categorisation, search, sharing	AI generation of study material
Collaborative curation: ratings, comments, revision history	Live video classes / real-time streaming
Reporting and administrator moderation of material	AI grading of essay / subjective answers
Quiz creation and management (MCQ, true/false)	Native mobile apps (responsive web only)
Quiz attempts, auto-scoring, feedback, history, progress dashboard, leaderboard	Institution-wide ERP / grade integration; multi-institution deployment

1.3 Audience

Course faculty and evaluators (read §4–§8), the project team as developers and testers (read the full document), and future maintainers.

1.4 Definitions

API Application Programming Interface · **JWT** JSON Web Token (signed, short-lived access token) · **Refresh token** long-lived, server-tracked token used to obtain new access tokens · **RBAC** Role-Based Access Control · **MERN** MongoDB, Express, React, Node.js · **MCQ** multiple-choice question · **T/F** true/false question · **Topic** a string label shared by material and quizzes, used for linkage, analytics and leaderboard scope · **Contributor** a privilege an administrator grants to a student (not a separate role) · **Attempt** one submitted set of answers to a quiz · **Answer key** the correct answer of a question · **RTM** Requirements Traceability Matrix · **SAD** Software Architecture & Design Specification · **STP** Software Test Plan · **TLS** Transport Layer Security · **OWASP** Open Worldwide Application Security Project.

1.5 References

- SE Level 3 Mini-Project Guidelines and Deliverables Part-1 (UE24CS341A).
- Submission 1: Synopsis / Project Proposal, Group 1 (v1.0). Submission 2: SRS v1.1.
- IEEE Std 830-1998 / ISO/IEC/IEEE 29148 (requirements specification).
- Coffee Kiosk exemplar (course reference document). OWASP Top 10 (2021).

2. Overall description

2.1 Product perspective

A new, self-contained MERN web product with a three-tier architecture: a React single-page client, a Node.js/Express REST API and a MongoDB database. External services are limited to an email service (password reset) and file/object storage (uploaded material). It does not depend on any legacy system.

2.2 Major product functions

- User registration, authentication (JWT + refresh token), logout and password reset.
- Role-based profiles: student, educator, administrator; contributor privilege for students.
- Study material upload with title, description, category, topic and tags; search and filter.
- Visibility control (private / shared / public), ratings, comments and revision history.
- Reporting of material and administrator moderation (dismiss / uphold).
- Quiz authoring with MCQ and T/F questions, answer keys, draft → published workflow, retake setting.
- Quiz attempts with automatic scoring, immediate per-question feedback and attempt history.
- Progress dashboard by topic and a leaderboard per quiz or topic.

2.3 User roles and characteristics

User class	Stored role	Characteristics & usage
Student	student	Primary user. Browses/searches material, rates and comments, attempts quizzes, views own progress and the leaderboard. Non-technical; peak use before exams.
Student with Contributor Privileges	student + contributor = true	Everything a student can do, plus upload and organise material and create quizzes. Not a separate database role.
Educator	educator	Trusted author of material and quizzes; manages own content. Does not attempt quizzes.
Administrator	admin	Manages users, roles and the contributor privilege; reviews reported material; may edit any material. Does not attempt quizzes.

2.4 Operating environment

- Client: latest two major versions of Chrome, Firefox, Edge and Safari on desktop and mobile (responsive).
- Server: Node.js 20 LTS on Linux, containerised with Docker; MongoDB 7.
- Network: HTTPS over the public internet.

2.5 Constraints

- Implemented on the MERN stack; source in Git/GitHub; CI/CD with Jenkins; containerised with Docker.
- Testing with Jest (unit/integration); static analysis with SonarQube; planning in Jira / GitHub Projects.
- REST API with JSON payloads; short-lived JWT access tokens plus server-tracked, revocable refresh tokens.
- Uploaded files limited to PDF, DOCX, PPTX, PNG and JPG, maximum 20 MB each.

2.6 Assumptions and dependencies

- Users have internet access and a supported browser.
- An email service (SMTP or provider API) is available for password-reset emails.
- File/object storage is available for uploaded material.
- The team has access to GitHub, Jenkins, Docker and SonarQube.

2.7 Business / domain rules

ID	Rule
BR-1	Only the author of a quiz or an administrator may edit, publish or unpublish it.
BR-2	A student may re-attempt a quiz only when the quiz's allowRetake setting is true. The student's highest score is used for the leaderboard and progress summaries.
BR-3	Only published quizzes can be attempted.
BR-4	Reported material is hidden from general users while under review. If the report is dismissed, the material is restored; if the report is upheld, it stays hidden.
BR-5	Uploaders confirm that they have the right to share the material they upload (copyright).

3. External interface requirements

3.1 User interfaces

- Responsive web UI with: Login / Register / Reset password, Material Library (search & filters), Material Detail (file, ratings, comments, revisions, report), Upload / Edit Material, Quiz Builder, Quiz Player, Result & Feedback, Attempt History, Progress Dashboard, Leaderboard, Profile, and Admin Console (users, reports).
- A consistent navigation bar that shows only the actions allowed for the user's role and privilege.
- Keyboard-accessible forms with inline validation messages next to the field in error.

3.2 Hardware interfaces

No special hardware. Any device with a supported browser and internet connection; the server runs on a standard cloud or VM host.

3.3 Software interfaces

Interface	Type	Purpose
MongoDB 7 (Mongoose ODM)	Database driver	Persist users, refresh tokens, material, comments, revisions, reports, quizzes and attempts
Email service (SMTP / provider API)	External API	Send password-reset links
File / object storage	Filesystem volume or S3-compatible API	Store uploaded study-material files
Platform REST API (/api/v1)	Internal HTTP/JSON	Client-server communication (specified in SAD §4.3)

3.4 Communications

- All client-server traffic uses HTTPS (TLS 1.2 or higher); plain HTTP is redirected to HTTPS.
- Authenticated requests carry **Authorization: Bearer <access JWT>**; the refresh token travels only in an HttpOnly, Secure, SameSite=Strict cookie.
- Email is sent over SMTPS or the provider's HTTPS API.

4. System features (detailed)

The project has **28 functional requirements** grouped into four features, one per team member. Each requirement has acceptance criteria and a reference to its test case in the STP (§13). IDs are kept from SRS v1.1 so that earlier references stay valid; gaps between number ranges are intentional grouping.

4.1 SF-1 User Accounts & Profiles (Owner: Anisha Nukul Niranjan)

Description: Lets users create an account, sign in securely, sign out, recover a forgotten password and manage their profile. Enforces roles. **Stimulus/response:** valid registration → account created; duplicate email → inline error; valid login → access + refresh tokens issued; logout → refresh token revoked.

Table SRS-1: SF-1 functional requirements

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
FR-001	The system shall allow a new user to register with a name, a unique email address and a password.	Functional	High	Student, Educator	AC: name 2–60 chars; valid email format; password ≥ 8 chars with at least one letter and one digit; duplicate email rejected with 409. New account gets role = student, contributor = false. Test: TC-AUTH-01–03	Password stored per SEC-001
FR-002	The system shall authenticate a registered user by email and password and issue a short-lived access token (JWT) together with a refresh token.	Functional	High	All users	AC: correct credentials → 200 with access token (expiry 15 min) and refresh cookie (expiry 7 days); wrong credentials → 401 with a generic message. Test: TC-AUTH-04, 05, 12, 13	SEC-002; SAD SD-1
FR-003	The system shall allow an authenticated user to log out, invalidating the active refresh token.	Functional	Medium	All users	AC: after logout, using the same refresh token returns 401 and no new access token is issued. Test: TC-AUTH-06	Server-tracked refresh tokens
FR-004	The system shall assign each account one role (student, educator or administrator) and enforce role-based access to protected features. An administrator may grant or revoke the contributor privilege for a student.	Functional	High	Administrator	AC: a non-admin calling an admin endpoint gets 403; after an admin grants contributor, that student can upload material; after revoke, upload returns 403 and nothing is stored (applies on the next request). Test: TC-AUTH-07, 08, 11, 21–25	SEC-003; UC-10a
FR-005	The system shall allow a user to view and edit their own profile details, excluding role and privilege.	Functional	Medium	All users	AC: name update saved; any role / contributor / email field sent by the user is rejected and the stored role is unchanged. Test: TC-AUTH-09, 14–20	Role changes only via FR-004
FR-006	The system shall allow a user to reset a forgotten password through a single-use emailed link.	Functional	Medium	All users	AC: link valid for 30 min and usable once; after reset the old password fails and the new one works; all of the user's refresh tokens are revoked. Test: TC-AUTH-10	Depends on email service

4.2 SF-2 Study Material Management & Moderation (Owner: Aryaroop Bose)

Description: Upload, organise, search, share and collaboratively curate study material, with reporting and administrator moderation. **Stimulus/response:** authorised upload with valid file → stored and confirmed; disallowed type or size → rejected; edit by owner/admin → new revision; report → material hidden pending review; admin decision → restored or kept hidden.

Table SRS-2: SF-2 functional requirements

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
FR-010	The system shall allow a Student with Contributor Privileges or an Educator to upload a study-material file with a title, description, category and topic.	Functional	High	Contributor, Educator	AC: valid upload → 201 and the material appears to its owner; title 3–120 chars, category and topic required; a plain student gets 403. Test: TC-MAT-01–03, 09, 10, 12, TC-SEC-06	File rules per SEC-006; SD-2
FR-011	The system shall allow the uploader to add one or more tags to study material.	Functional	Medium	Contributor, Educator	AC: 1–10 tags, each 1–30 chars, stored lower-case without duplicates. Test: TC-MAT-01, 11	Used by FR-012
FR-012	The system shall allow users to search and filter material by keyword, tag or category.	Functional	High	All users	AC: results include only material the user may see (FR-013, BR-4) and match all chosen filters; results are paginated (20 per page). Test: TC-MAT-04, 13–16, 18, 19	Text index on title, description, tags
FR-013	The system shall let an owner set material visibility to private (owner only), shared (owner plus users in sharedWith) or public (all signed-in users).	Functional	Medium	Contributor, Educator	AC: a private item returns 404 to other users; a shared item is visible only to listed users; a public item is visible to all signed-in users. Test: TC-MAT-05, 17, 18, 23, 29	New uploads default to private
FR-014	The system shall allow any authenticated user to rate (integer 1–5) and comment on study material they can access, with each comment stored as a separate record.	Functional	Medium	All users	AC: one rating per user per material (re-rating replaces the old value); the average updates; values outside 1–5 are rejected; comment 1–1000 chars. Test: TC-MAT-06, 20–25, TC-SEC-04	Comments sanitised (SEC-004)
FR-015	The system shall create and keep a revision record whenever the owner or an administrator updates study material (file and/or metadata), capturing the previous state.	Functional	Low	Contributor, Educator	AC: each update creates a revision with versionNo = previous + 1 and the old title, description, category, topic, tags and fileUrl; revisions are listed newest first. Test: TC-MAT-07, 26–28	MaterialRevision collection
FR-016	The system shall allow an authenticated Student, Student with Contributor Privileges or Educator to report study material by choosing a reason and submitting it for administrator review.	Functional	Medium	All users	AC: report saved with status = open; the material is hidden from general listings (BR-4); a user can have only one open report per material. Test: TC-MOD-01, 05–11	UC-11
FR-017	The system shall allow an administrator to review reported material and either dismiss the report (restoring visibility) or uphold it (keeping the material hidden).	Functional	Medium	Administrator	AC: dismiss → status dismissed, material visible again; uphold → status actioned, material stays hidden; reviewerId is recorded; non-admins get 403. Test: TC-MOD-02–04, 12–16	UC-10b
FR-018	The system shall allow the material owner or an administrator to edit the title, description,	Functional	Medium	Contributor, Educator,	AC: owner or admin edit → 200 and a revision is created; any other user → 403. Test: TC-MAT-07, 08,	“Organise material” in UC-05b

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
	category, topic and tags of the material; each edit creates a revision (FR-015).			Administrator	28	

4.3 SF-3 Quiz Creation, Management & Leaderboard (Owner: Ayush Ravindra Paithankar)

Description: Authors build topic-linked quizzes with MCQ and true/false questions and answer keys, and move them between draft and published. The leaderboard ranks students using stored attempt scores. **Stimulus/response:** author saves questions → validated and saved as a draft; publish request with ≥ 1 valid question → published; otherwise rejected.

Table SRS-3: SF-3 functional requirements

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
FR-020	The system shall allow a Student with Contributor Privileges or an Educator to create a quiz with a title and an associated topic.	Functional	High	Contributor, Educator	AC: title 3–120 chars and topic required; quiz saved with status = draft; a plain student gets 403. Test: TC-QZ-01, 08	SD-3
FR-021	The system shall support at least two question types: multiple-choice (single correct answer) and true/false.	Functional	High	Contributor, Educator	AC: a quiz can contain both types; any other type value is rejected with 400. Test: TC-QZ-01, 03	
FR-022	The system shall require the author to define an answer key for every question: each MCQ needs 2–6 options and exactly one correct option; each T/F question needs a true or false answer.	Functional	High	Contributor, Educator	AC: MCQ with 1 option, more than 6 options, or no correct option → 400; MCQ with 2 options and a key → accepted. Test: TC-QZ-02, 03	Validation in QuizService
FR-023	The system shall allow the author to edit, publish and unpublish a quiz and to set whether re-attempts are allowed (allowRetake).	Functional	Medium	Contributor, Educator	AC: publish → status published; unpublish → status draft and it can no longer be attempted; only the author or an admin may do this (BR-1). Test: TC-QZ-05, 06	Default allowRetake = true
FR-024	The system shall link a quiz with study material through a shared topic value (no direct foreign key).	Functional	Low	Student	AC: filtering quizzes by topic returns only matching published quizzes; a material detail page lists published quizzes with the same topic. Test: TC-QZ-07	Topic matched case-insensitively
FR-025	The system shall prevent a quiz from being published unless it contains at least one valid question with an answer key.	Functional	High	Course faculty	AC: publishing a quiz with zero valid questions → 422 QUIZ_NOT_PUBLISHABLE and status stays draft. Test: TC-QZ-04	
FR-035	The system shall display a leaderboard for a chosen quiz or topic, ranking students by their highest score (highest first). Equal scores share a rank and the next rank is skipped (1, 1, 3). For a topic leaderboard, the student's ranking score	Functional	Low	Student	AC: scores A = 8, B = 8, C = 6 → ranks 1, 1, 3; if a student scored 5 then 8, 8 is used; topic ranking uses the sum of each student's best percentage per quiz in that topic. Test: TC-LB-01–09	Reads Attempt records from SF-4; does not compute scores

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
	shall be the sum of the highest percentage score obtained by that student on each published quiz in the topic.					

4.4 SF-4 Quiz Attempts, Scoring & Progress Analytics (Owner: Bharat V Bhat)

Description: Students attempt published quizzes, are scored automatically on the server, see feedback immediately, and track progress. Only students (including contributors) attempt quizzes. **Stimulus/response:** student submits answers → auto-scored against the key → attempt stored → score and per-question feedback shown → analytics and leaderboard updated.

Table SRS-4: SF-4 functional requirements

Req ID	Requirement (shall...)	Type	Priority	Source / Stakeholder	Acceptance criteria / Test case ref	Comments / Dependencies
FR-030	The system shall allow an authenticated student to attempt a published quiz and submit answers, subject to the quiz's allowRetake setting.	Functional	High	Student	AC: published quiz → 201; draft/unpublished quiz → 404 (BR-3); second submission with allowRetake = false → 409; educator/admin submission → 403. Test: TC-ATT-01–03, 09	SD-4
FR-031	The system shall automatically score a submitted attempt against the answer key on the server: 1 point per correct answer, 0 per incorrect answer, and 0 per unanswered question.	Functional	High	Student, Course faculty	AC: 5 questions with 3 correct, 1 wrong, 1 blank → score 3, maxScore 5; any score value sent by the client is ignored; answers to unknown question IDs → 400. Test: TC-ATT-04–06	ScoringService is a pure function
FR-032	The system shall display the score and per-question feedback (correct / incorrect / unanswered and the correct answer) immediately after submission.	Functional	High	Student	AC: the submit response contains score, maxScore and one result per question; the result screen renders without a page reload. Test: TC-ATT-07	Answer keys shown only after submission (SEC-008)
FR-033	The system shall store each attempt and let the student view their own attempt history.	Functional	Medium	Student	AC: history lists quiz title, score, maxScore and submittedAt, newest first; a student cannot open another student's attempt (403). Test: TC-ATT-08, 10–12	NFR-007
FR-034	The system shall show a progress dashboard summarising the student's performance by topic over time, using the highest score per quiz.	Functional	Medium	Student	AC: for each topic, show quizzes attempted and the average of best-score percentages; show a timeline of attempts. Example: best scores 80 % and 60 % in one topic → topic average 70 %. Test: TC-ANL-01–06	Aggregation over Attempt records

5. Non-functional requirements (detailed)

NFRs are measurable and tied to tests in the STP. Load figures assume the reference test environment in STP §6.

Table SRS-5: Non-functional requirements

Req ID	Requirement	Category	Priority	Acceptance criteria / Measurement
NFR-001	With up to 100 concurrent active users, 95 % of page loads shall complete within 3 s and quiz auto-scoring (submit request) shall return within 2 s.	Performance	High	k6 load test, 100 virtual users for 10 min: p95 page load ≤ 3 s; p95 POST /attempts ≤ 2 s. Test: TC-PERF-01
NFR-002	The system shall support at least 100 concurrent active users without functional errors.	Scalability	High	Same load run: 0 % HTTP 5xx and 100 % of functional checks pass. Test: TC-PERF-02
NFR-003	The system shall maintain ≥ 99 % availability during a continuous 24-hour evaluation window (start time agreed with the course faculty).	Availability	Medium	Uptime probe on /api/v1/health every 30 s for 24 h (2,880 probes); $\geq 2,852$ successful (≥ 99 %, i.e. at most ≈ 14 min downtime). Test: TC-AVL-01
NFR-004	At least 4 of 5 first-time users shall complete a quiz attempt without help; every form shall show inline validation messages.	Usability	Medium	Moderated usability session with 5 new users; ≥ 4 succeed; every form checked for inline errors. Test: TC-UX-01
NFR-005	Code shall pass the SonarQube quality gate with no blocker or critical issues, and unit-test line coverage shall be ≥ 70 % on core modules.	Maintainability	High	SonarQube report + Jest coverage report (auth, material, quiz, attempt, scoring services). Test: TC-MNT-01
NFR-006	The UI shall work correctly on the latest two versions of Chrome, Firefox, Edge and Safari.	Portability	Medium	Automated Playwright smoke suite passes on Google Chrome and Microsoft Edge (branded channels), Firefox, and WebKit (Safari engine); a manual smoke test on real Safari (macOS / iOS) is performed where a device is available. Test: TC-PORT-01
NFR-007	A submitted quiz attempt that has received a success response shall never be lost during normal operation.	Reliability	High	After 201, restarting the API container leaves the attempt stored; 100 parallel submits create exactly 100 records. Test: TC-REL-01
NFR-008	Core business services shall be testable on their own; automated unit tests shall run without the production UI.	Testability	Medium	Unit suite runs headless in the CI pipeline using mocks / in-memory MongoDB. Test: TC-TST-01

5.1 Security

5.1.1 Security objectives

ID	Security objective	Realised by
SO-1	Protect identities and sessions. Only the real account holder can sign in and act as that user; stolen or old sessions cannot be reused.	SEC-001, SEC-002, SEC-005
SO-2	Enforce least-privilege access. Users can perform only the actions allowed for their role and privilege, and can change only resources they own (unless they are an administrator).	SEC-003, SEC-007
SO-3	Preserve the integrity of content and assessments. Malicious input and files are rejected, answer keys stay secret until submission, and scores are computed only by the server.	SEC-004, SEC-006, SEC-008, FR-031

5.1.2 Security requirements

Table SRS-6: Security requirements

Req ID	Requirement (shall...)	Type	Priority	Acceptance criteria / Test case ref
SEC-001	The system shall store passwords only as salted bcrypt hashes (cost ≥ 10); plaintext passwords shall never be stored or logged.	Security	High	DB inspection shows \$2b\$ hashes; log search for a test password returns nothing. Test: TC-SEC-01
SEC-002	The system shall authenticate API requests with signed, expiring access tokens (JWT) and shall revoke the refresh token on logout.	Security	High	Expired, tampered or missing token $\rightarrow$ 401; revoked refresh token cannot obtain a new access token. Test: TC-SEC-02, TC-AUTH-06
SEC-003	The system shall enforce role-based authorisation on the server for every protected endpoint.	Security	High	Role $\times$ endpoint matrix test: every disallowed call $\rightarrow$ 403, every allowed call succeeds. Test: TC-SEC-03
SEC-004	The system shall validate and sanitise all inputs to prevent NoSQL injection and cross-site scripting (XSS).	Security	High	Operator payloads such as {"\$gt": ""} $\rightarrow$ 400; <script> in comments is stored/rendered as inert text. Test: TC-SEC-04
SEC-005	All client-server communication shall use HTTPS with TLS 1.2 or higher.	Security	High	HTTP redirects to HTTPS; TLS 1.0/1.1 handshakes refused; HSTS header present. Test: TC-SEC-05
SEC-006	The system shall accept only PDF, DOCX, PPTX, PNG and JPG files up to 20 MB, checking both the extension and the file signature, and reject everything else.	Security	High	20 MB file accepted; 20 MB + 1 byte $\rightarrow$ 413; .exe renamed to .pdf $\rightarrow$ 415. Test: TC-SEC-06
SEC-007	The system shall enforce resource ownership so a user cannot modify or delete another user's material or quizzes unless they are an administrator.	Security	High	User B editing or deleting user A's material or quiz $\rightarrow$ 403. Test: TC-SEC-07
SEC-008	The system shall not expose quiz answer keys to a student before that student submits the attempt.	Security	High	GET quiz as a student returns no answerKey field anywhere in the JSON. Test: TC-SEC-08

Totals: 28 functional requirements, 8 non-functional requirements, 3 security objectives and 8 security requirements (template minimum: 15 / 5 / 2 / 5).

6. Quality attributes & Acceptance tests

- **Exit criteria for acceptance:** all High-priority functional and security requirements are implemented and verified; no open Critical or High defects; NFR-001, NFR-002 and NFR-005 targets are met; the RTM shows every requirement linked to at least one passed test.
- **Acceptance test suites (STP §13):** Accounts & Authentication (TC-AUTH), Study Material (TC-MAT), Moderation (TC-MOD), Quiz Management (TC-QZ), Leaderboard (TC-LB), Attempts & Scoring (TC-ATT), Analytics (TC-ANL), Performance (TC-PERF), Availability (TC-AVL), Usability (TC-UX), Maintainability (TC-MNT), Portability (TC-PORT), Reliability (TC-REL), Testability (TC-TST) and Security (TC-SEC).

Quality attribute	Scenario	Measure
Performance	100 students submit quizzes during an exam-week peak	p95 scoring response ≤ 2 s
Security	A student edits a request to call an admin endpoint	403 returned; event logged
Integrity	A student inspects network traffic before submitting	No answer keys in any response
Reliability	API container restarts right after an attempt is saved	Attempt still present
Usability	A first-time user attempts a quiz	≥ 4 of 5 users succeed unaided

7. System models and diagrams

7.1 UML Use-Case diagrams

Two use-case diagrams split the system by concern. Diagram 1 covers learning and self-assessment; Diagram 2 covers authoring and administration. “Student with Contributor Privileges” is a specialisation of Student and inherits every Student use case.

UC Diagram 1 - Learning & Self-Assessment

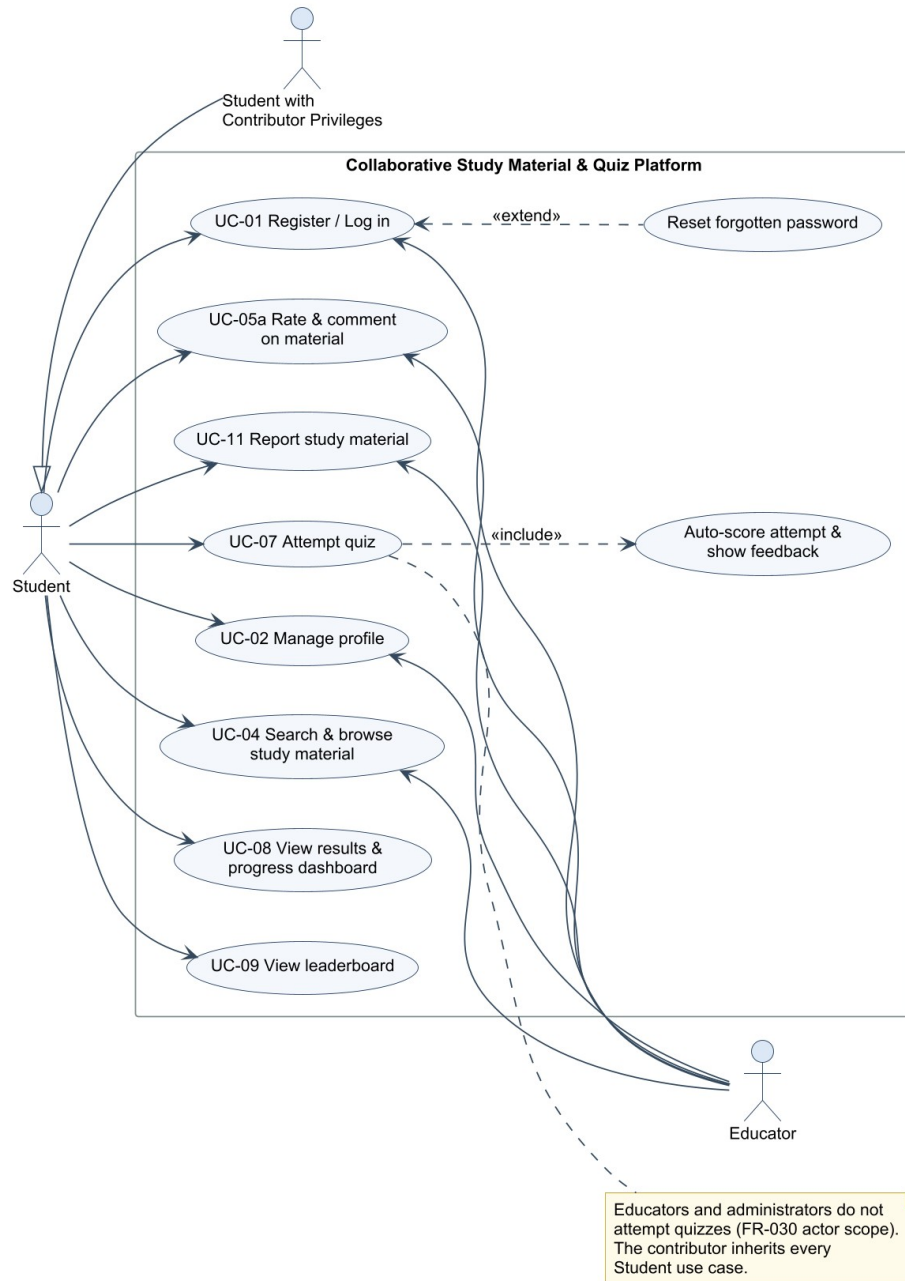


Figure SRS-1: UML Use-Case Diagram 1 — Learning & Self-Assessment

UC Diagram 2 - Content Authoring & Administration

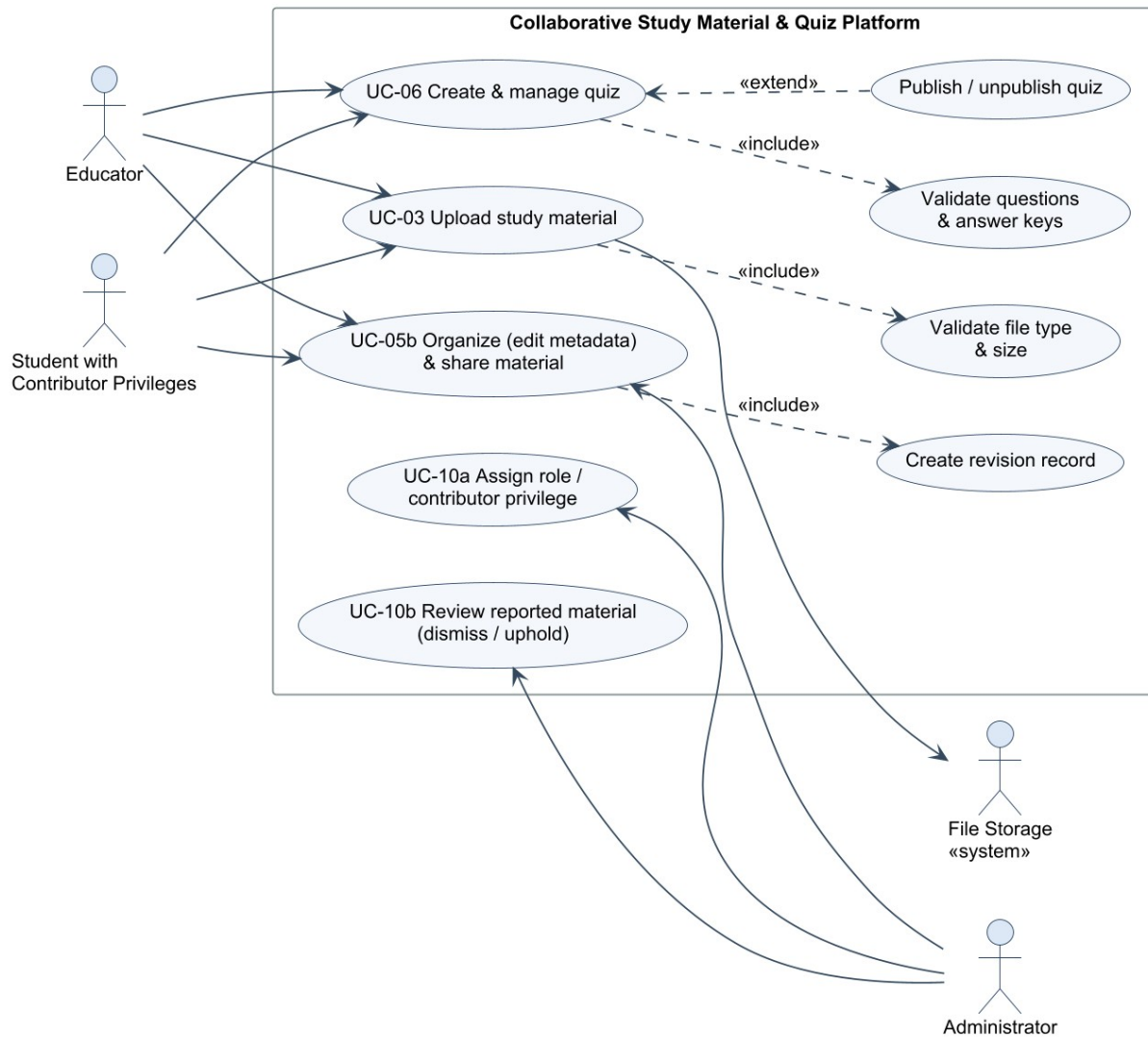


Figure SRS-2: UML Use-Case Diagram 2 — Content Authoring & Administration

7.2 Use-case descriptions

UC	Use case	Primary actor(s)	Pre-condition	Main flow → Outcome	FRs
UC-01	Register / Log in (+ reset password)	Student, Educator	App reachable	Enter details → validated → account / session created; forgotten password → emailed link	FR-001–003, 006
UC-02	Manage profile	Any signed-in user	Signed in	Edit name → saved (role unchanged)	FR-005
UC-03	Upload study material	Contributor, Educator	Signed in with authoring rights	Choose file + metadata → validated → stored (private by default)	FR-010, 011
UC-04	Search & browse material	All users	Signed in	Keyword + filters → paginated visible results	FR-012, 013
UC-05a	Rate & comment	All users	Can see the material	Give 1–5 rating / comment → saved; average updated	FR-014
UC-05b	Organise & share material	Owner, Administrator	Owns material (or admin)	Edit metadata / visibility / sharedWith → revision created	FR-013, 015, 018
UC-06	Create & manage quiz	Contributor, Educator	Authoring rights	Add questions + keys → draft → publish / unpublish	FR-020–025

UC	Use case	Primary actor(s)	Pre-condition	Main flow → Outcome	FRs
UC-07	Attempt quiz	Student	Student signed in; quiz published	Answer → submit → auto-score → feedback. Alternates: allowRetake = false and an attempt already exists → 409, nothing stored; quiz not published → 404; abandon → nothing stored	FR-030–032
UC-08	View results & progress	Student	Has attempts	Open history / dashboard → scores and topic summary	FR-033, 034
UC-09	View leaderboard	Student	Quiz or topic chosen	Ranked list by best score	FR-035
UC-10a	Assign role / contributor	Administrator	Admin signed in	Select user → change role / privilege	FR-004
UC-10b	Review reported material	Administrator	Open report exists	Dismiss (restore) or uphold (keep hidden)	FR-017
UC-11	Report study material	Student, Contributor, Educator	Can see the material	Choose reason → report open → material hidden	FR-016

7.3 Conceptual data model

Leaderboard and progress data are derived from stored Attempt records and are not separate entities. Field-level layouts are in SAD §3.6.

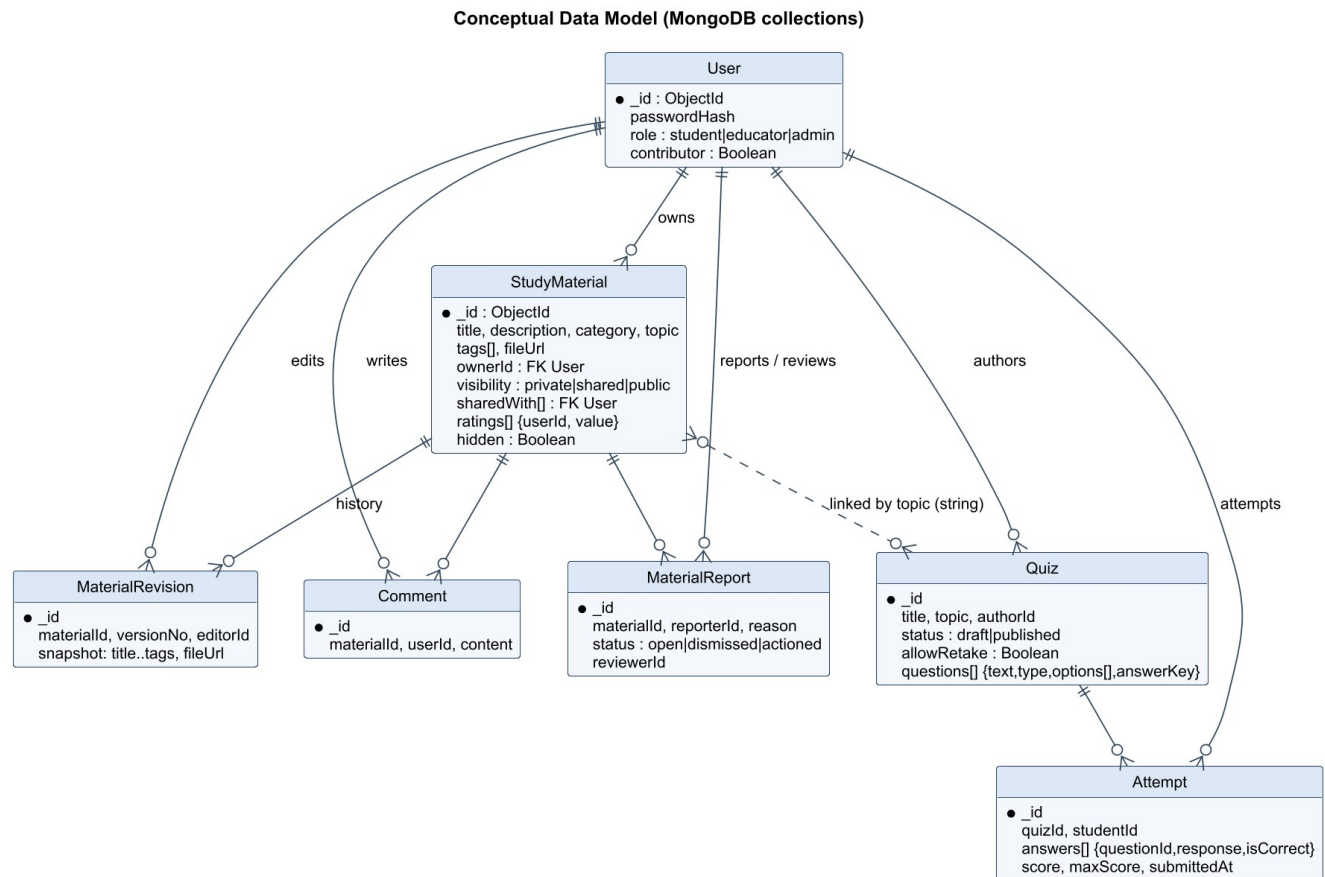


Figure SRS-3: Conceptual data model (MongoDB collections)

8. Requirements Traceability Matrix (RTM)

Status: **N** = not yet tested, **P** = partially passed, **A** = all linked tests passed. Design references point to the SAD in this document (C-xxx = component §3.4, SD-n = sequence diagram §4.2, API = §4.3). Test cases are specified in STP §13.

Table SRS-7: Requirements Traceability Matrix

Req ID	Requirement short	Section ref / Design spec	Module	Test case(s)	Status (N/P/A)	Comments
FR-001	Register with unique email	4.1 / C-AUTH, API-AUTH	Auth & User	TC-AUTH-01–03	N	
FR-002	Login, JWT + refresh token	4.1 / C-AUTH, SD-1	Auth & User	TC-AUTH-04, 05, 12, 13	N	
FR-003	Logout revokes refresh token	4.1 / C-AUTH, SD-1	Auth & User	TC-AUTH-06	N	
FR-004	Roles + contributor privilege	4.1 / C-GW RBAC, C-AUTH	Auth & User	TC-AUTH-07, 08, 11, 21–25	N	
FR-005	Edit own profile	4.1 / C-AUTH, API-USER	Auth & User	TC-AUTH-09, 14–20	N	
FR-006	Password reset by email	4.1 / C-AUTH, C-MAIL	Auth & User	TC-AUTH-10	N	
FR-010	Upload material	4.2 / C-MAT, C-STO, SD-2	Study Material	TC-MAT-01–03, 09, 10, 12, TC-SEC-06	N	
FR-011	Tag material	4.2 / C-MAT	Study Material	TC-MAT-01, 11	N	
FR-012	Search & filter	4.2 / C-MAT, API-MAT	Study Material	TC-MAT-04, 13–16, 18, 19	N	
FR-013	Visibility private/shared/public	4.2 / C-MAT	Study Material	TC-MAT-05, 17, 18, 23, 29	N	
FR-014	Rate & comment	4.2 / C-MAT	Study Material	TC-MAT-06, 20–25, TC-SEC-04	N	
FR-015	Revision history	4.2 / C-MAT	Study Material	TC-MAT-07, 26–28	N	
FR-016	Report material	4.2 / C-MOD	Moderation	TC-MOD-01, 05–11	N	
FR-017	Admin dismiss / uphold	4.2 / C-MOD	Moderation	TC-MOD-02–04, 12–16	N	
FR-018	Edit metadata (organise)	4.2 / C-MAT	Study Material	TC-MAT-07, 08, 28	N	
FR-020	Create quiz	4.3 / C-QUIZ, SD-3	Quiz	TC-QZ-01, 08	N	
FR-021	MCQ + T/F question types	4.3 / C-QUIZ	Quiz	TC-QZ-01, 03	N	
FR-022	Answer key rules	4.3 / C-QUIZ, SD-3	Quiz	TC-QZ-02, 03	N	
FR-023	Edit / publish / unpublish, allowRetake	4.3 / C-QUIZ, SD-3	Quiz	TC-QZ-05, 06	N	
FR-024	Topic linkage	4.3 / C-QUIZ, C-MAT	Quiz	TC-QZ-07	N	
FR-025	Publish gate	4.3 / C-QUIZ, SD-3	Quiz	TC-QZ-04	N	
FR-035	Leaderboard ranking	4.3 / C-ANL	Analytics & Leaderboard	TC-LB-01–09	N	

Req ID	Requirement short	Section ref / Design spec	Module	Test case(s)	Status (N/P/A)	Comments
FR-030	Attempt published quiz	4.4 / C-ATT, SD-4	Attempt & Scoring	TC-ATT-01–03, 09	N	
FR-031	Auto-scoring rules	4.4 / C-ATT ScoringService, SD-4	Attempt & Scoring	TC-ATT-04–06	N	
FR-032	Immediate feedback	4.4 / C-ATT, SD-4	Attempt & Scoring	TC-ATT-07	N	
FR-033	Attempt history	4.4 / C-ATT	Attempt & Scoring	TC-ATT-08, 10–12	N	
FR-034	Progress dashboard	4.4 / C-ANL	Analytics & Leaderboard	TC-ANL-01–06	N	
NFR-001	Response-time targets	5 / deployment, indexes	All	TC-PERF-01	N	
NFR-002	100 concurrent users	5 / deployment	All	TC-PERF-02	N	
NFR-003	≥ 99 % over 24-h window	5 / health endpoint	All	TC-AVL-01	N	
NFR-004	Usability + inline validation	5 / UX §4.5	React SPA	TC-UX-01	N	
NFR-005	Sonar gate + 70 % coverage	5 / CI pipeline	All	TC-MNT-01	N	
NFR-006	Browser portability	5 / C-UI	React SPA	TC-PORT-01	N	
NFR-007	No lost attempts	5 / C-ATT, write concern	Attempt & Scoring	TC-REL-01	N	
NFR-008	Testable services	5 / layered design §4.1	All	TC-TST-01	N	
SEC-001	bcrypt password hashes	5.1 / C-AUTH	Auth & User	TC-SEC-01	N	
SEC-002	JWT + refresh revocation	5.1 / C-GW, SD-1	Auth & User	TC-SEC-02, TC-AUTH-06	N	
SEC-003	Server-side RBAC	5.1 / C-GW RBAC	All protected	TC-SEC-03	N	
SEC-004	Input validation / sanitising	5.1 / C-GW validator	All	TC-SEC-04	N	
SEC-005	HTTPS / TLS 1.2+	5.1 / deployment (nginx)	Infrastructure	TC-SEC-05	N	
SEC-006	Upload type & size check	5.1 / C-GW upload, SD-2	Study Material	TC-SEC-06	N	
SEC-007	Ownership checks	5.1 / C-GW ownership guard	Material, Quiz	TC-SEC-07	N	
SEC-008	Hide answer keys	5.1 / C-QUIZ toStudentView, SD-4	Quiz, Attempt	TC-SEC-08	N	

Software Architecture and Design Specification (SAD)

Collaborative Study Material & Quiz Platform

Field	Details
Project	Collaborative Study Material & Quiz Platform
Version	1.0
Authors	Anisha Nukul Niranjana, Aryaroop Bose, Ayush Ravindra Paithankar, Bharat V Bhat (Team Lead)
Date	02-10-2026
Status	Baselined for Submission (Deliverables Part-1)

Revision History

Version	Date	Author	Change Summary
1.0	02-10-2026	Team 1	First architecture & design baseline derived from SRS v1.2

Approvals

Role	Name	Signature/Date
Course Faculty	Dr Sapna V M	
Team Lead / Architecture review	Bharat V Bhat	
API review	Anisha Nukul Niranjana	

1. Introduction

1.1 Purpose. This document specifies the architecture and detailed design of the Collaborative Study Material & Quiz Platform. It shows how each requirement in SRS v1.2 maps to components, data, interfaces and security controls, and gives developers a shared contract for implementation.

1.2 Scope. Covers the React client, the Node.js/Express REST API (six functional modules — auth, materials, moderation, quizzes, attempts, analytics — supported by a shared security and request pipeline), the MongoDB data model, file storage and email integration, deployment with Docker, and the security architecture. Implementation code, test cases and results are out of scope (see STP).

1.3 Audience. Team developers and testers, the API reviewer, course faculty/evaluators and future maintainers.

1.4 Definitions. ADR (Architecture Decision Record), API, DAL (Data Access Layer), DTO (Data Transfer Object), JWT, ODM (Object Document Mapper – Mongoose), RBAC, SPA (Single-Page Application), STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege), TLS. Other terms as in SRS §1.4.

2. Document Overview

2.1 How to use this document. §3 describes the architecture (components, pattern, technology, data stores, risks, traceability, security). §4 describes the design (module internals, sequence diagrams, API contract, error handling, UX). Component IDs (C-xxx) and sequence IDs (SD-n) are used by the SRS RTM and the STP.

2.2 Related Documents. SRS v1.2 and STP v1.0 (both in this combined submission); Synopsis v1.0; Coffee Kiosk exemplar.

3. Architecture

3.1 Goals & Constraints

Goal	How the architecture supports it	Driver
Security of accounts, content and assessments	Single security pipeline in front of every route; server-side scoring; answer keys removed from student responses	SEC-001–008
Performance: p95 page ≤ 3 s, scoring ≤ 2 s at 100 users	Stateless API, MongoDB indexes, static SPA served by nginx, pure in-memory scoring	NFR-001, NFR-002
Maintainability & testability	Layered modules with services isolated from Express and the database; dependency injection of repositories	NFR-005, NFR-008
Independent ownership by four developers	One backend module + one UI area per owner with agreed API contracts	Course guidelines
Reliability of attempts	Atomic single-document insert with majority write concern before returning 201	NFR-007

Constraints: MERN stack; Docker; Jenkins CI; Jest; SonarQube; files ≤ 20 MB of five allowed types; a single small team and semester-long schedule, so the system must stay simple to deploy and run.

3.2 Stakeholders & Concerns

Stakeholder	Primary concerns
Students	Fast search, fair and correct scoring, immediate feedback, privacy of results
Contributors & Educators	Easy upload and quiz authoring, control over visibility, protection of their content
Administrators	Role management, efficient moderation, platform health
Course faculty (evaluator)	Traceability from requirement to test, security validation, clear SDLC evidence
Developers (team)	Modularity, clear contracts between modules, testability, simple local setup

3.3 Component (UML) Diagram

Component Diagram - Collaborative Study Material & Quiz Platform

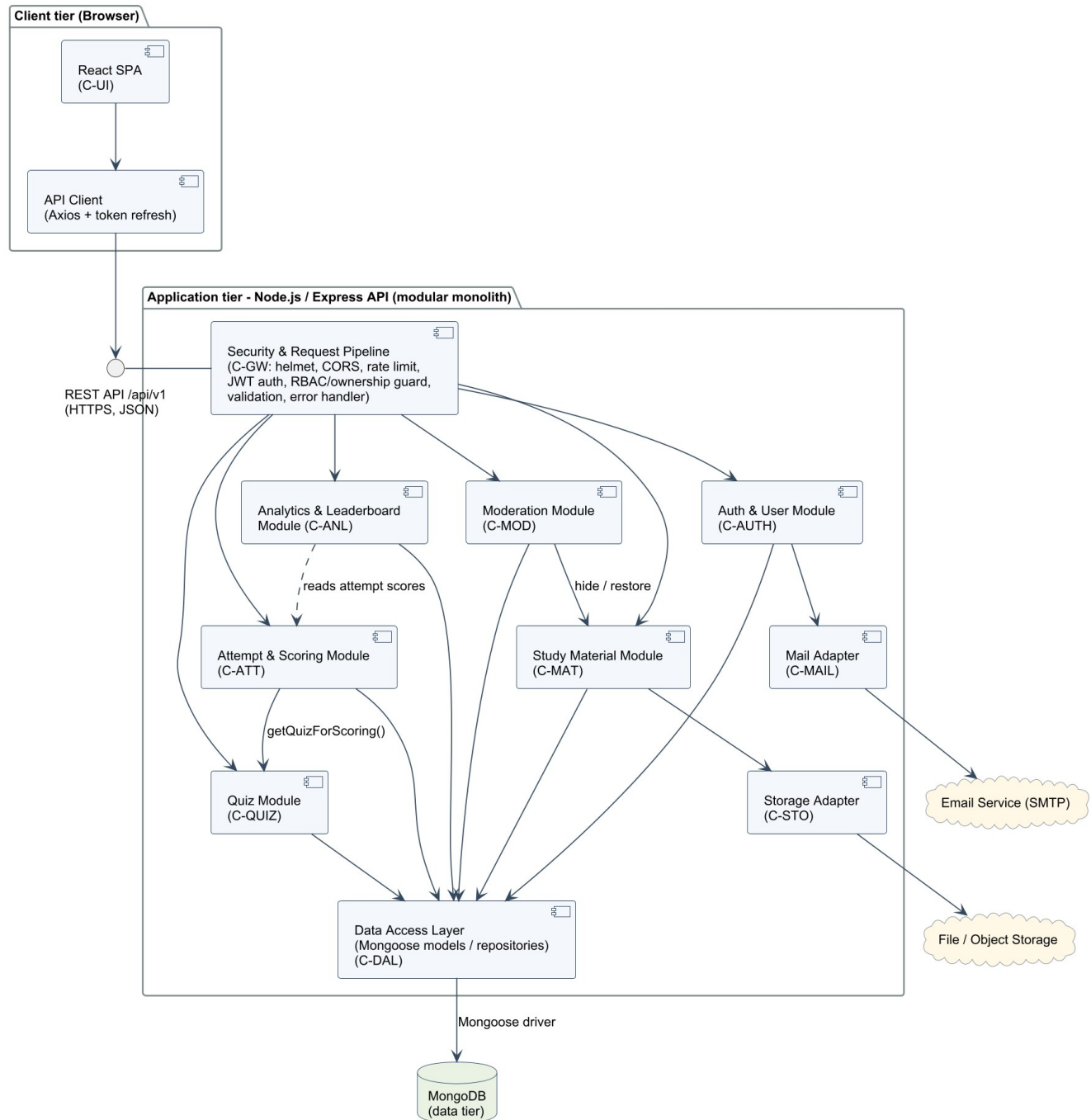


Figure SAD-1: UML component diagram (logical view)

3.3.1 Domain class diagram

The class diagram shows the main domain classes held in MongoDB (embedded value objects use composition) and the domain operations used by the services.

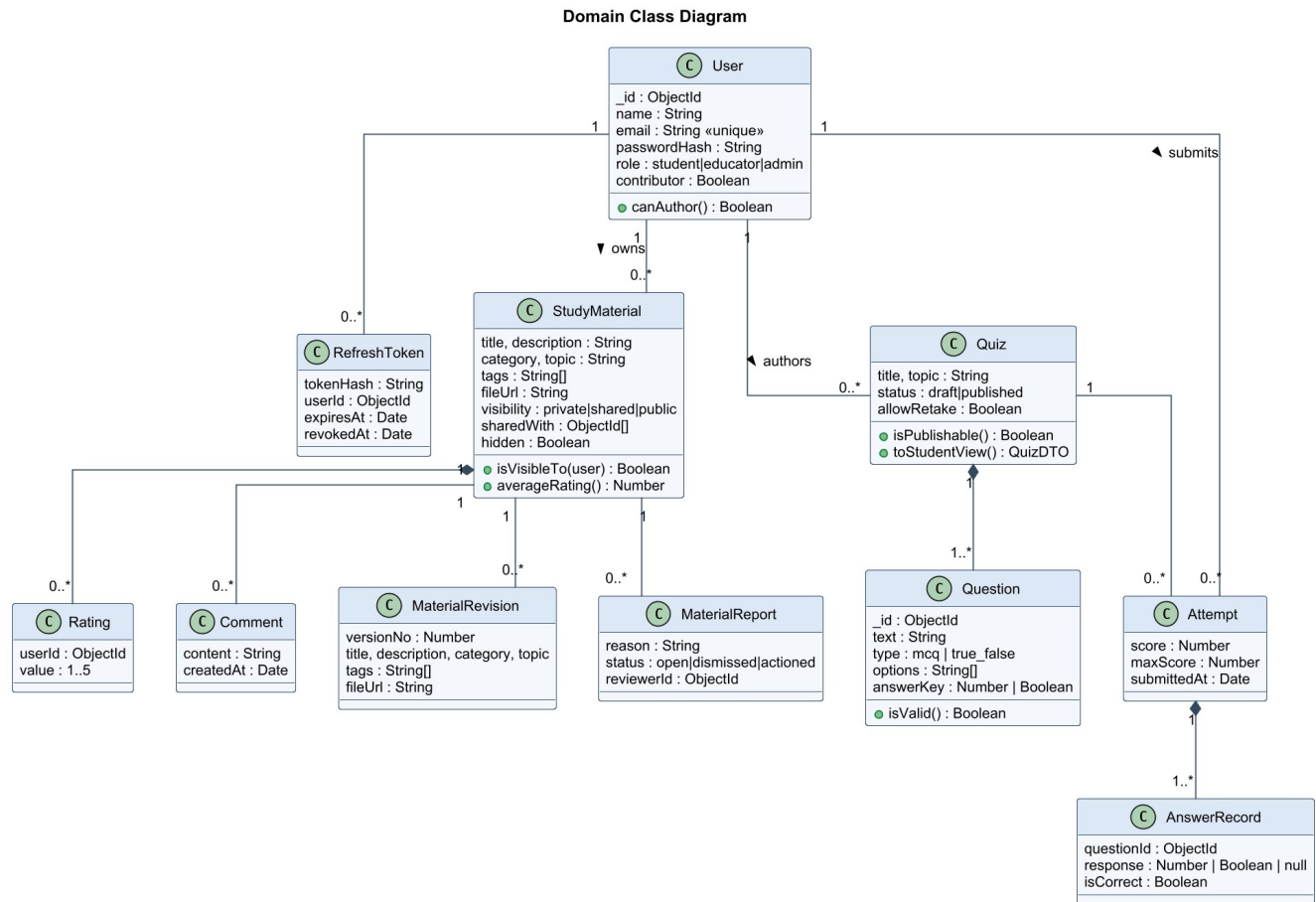


Figure SAD-2: UML class diagram of the domain model

3.4 Component Descriptions

ID	Component	Responsibility	Provided interface	Owner	Requirements
C-UI	React SPA	Pages, routing, role-aware navigation, forms with inline validation, quiz player, dashboards	Browser UI	Aryaroop (UI/UX lead); each owner builds their pages	NFR-004, NFR-006
C-GW	Security & request pipeline	helmet headers, CORS, rate limiting, JWT authentication, RBAC & ownership guards, schema validation and sanitising, upload filter, central error handler, request logging	Express middleware chain	Anisha (auth parts), Bharat (error handling/logging)	SEC-002–007
C-AUTH	Auth & User module	Register, login, refresh, logout, password reset, profile, admin role/privilege management	/auth/*, /users/*, /admin/users/*	Anisha	FR-001–006, SEC-001
C-MAT	Study Material module	Upload, metadata, tags, search, visibility, sharing, ratings, comments, revisions	/materials/*	Aryaroop	FR-010–015, FR-018
C-MOD	Moderation module	Create reports, hide material, admin review queue, dismiss / uphold	/materials/{id}/reports, /admin/reports/*	Aryaroop	FR-016, FR-017, BR-4
C-QUIZ	Quiz module	Quiz CRUD, question validation, publish gate, student view without keys, topic linkage	/quizzes/*; getQuizForScoring()	Ayush	FR-020–025, SEC-008
C-ATT	Attempt & Scoring module	Submit attempts, retake rule, ScoringService, feedback, attempt history	/quizzes/{id}/attempts, /attempts/*	Bharat	FR-030–033, NFR-007
C-ANL	Analytics &	Progress dashboard aggregation (Bharat)	/analytics/me/progress,	Bharat / Ayush	FR-034, FR-035

ID	Component	Responsibility	Provided interface	Owner	Requirements
	Leaderboard module	and leaderboard ranking (Ayush) over Attempt data	/leaderboard		
C-DAL	Data Access Layer	Mongoose schemas, indexes and repository functions; the only layer that talks to MongoDB	Repository functions	Ayush (database lead)	All
C-STO	Storage adapter	Save, stream and delete files on a Docker volume or S3-compatible bucket behind one interface	put(), get(), remove()	Aryaroop	FR-010
C-MAIL	Mail adapter	Send password-reset emails; console stub in development and test	sendResetLink()	Anisha	FR-006

3.5 Chosen Architecture Pattern and Rationale

Pattern: three-tier client-server with a layered, modular-monolith REST backend. The browser runs a React SPA (presentation tier). The Express API (application tier) is one deployable unit split into feature modules; inside each module, code is layered: routes → middleware → controller → service → repository. MongoDB is the data tier. Requests flow one way: UI → REST API → middleware → controller → service → repository → database.

Option	Decision	Reason
Layered modular monolith (chosen)	Accepted	Clear separation of concerns, one Docker image to build and deploy, easy to test services in isolation (NFR-008), and module boundaries match the four owners.
Microservices	Rejected	Network calls, service discovery and distributed data add complexity a 4-person team cannot justify at 100-user scale.
Server-rendered MVC (EJS)	Rejected	Weaker interactive UX for the quiz player and dashboards; the course stack expects React.
Backend-as-a-Service (e.g. Firebase)	Rejected	Hides the API/design work that the course evaluates and does not fit the MERN constraint.

Key decisions (ADR summary): ADR-1 stateless JWT access tokens plus server-stored refresh tokens (revocable logout without a session store). ADR-2 embed questions inside the Quiz document and answers inside the Attempt document, so each is read and written atomically. ADR-3 compute the leaderboard and dashboard with MongoDB aggregation on demand instead of storing them (single source of truth). ADR-4 ScoringService is a pure function with no I/O, so it is easy to unit test.

3.6 Technology Stack & Data Stores

Layer	Technology
Frontend	React 18, React Router, Axios, React Hook Form + Zod (inline validation), Vite build
Backend	Node.js 20 LTS, Express 4, Mongoose 8, jsonwebtoken, bcrypt, multer, file-type, helmet, cors, express-rate-limit, express-mongo-sanitize, pino logging
Data stores	MongoDB 7 (main data); Docker volume or S3-compatible bucket (files)
Infrastructure	Docker + Docker Compose (nginx, api, mongo containers), nginx for TLS and static files, Jenkins CI/CD, SonarQube
Testing	Jest, Supertest, mongodb-memory-server, React Testing Library, Playwright, k6, OWASP ZAP, Postman

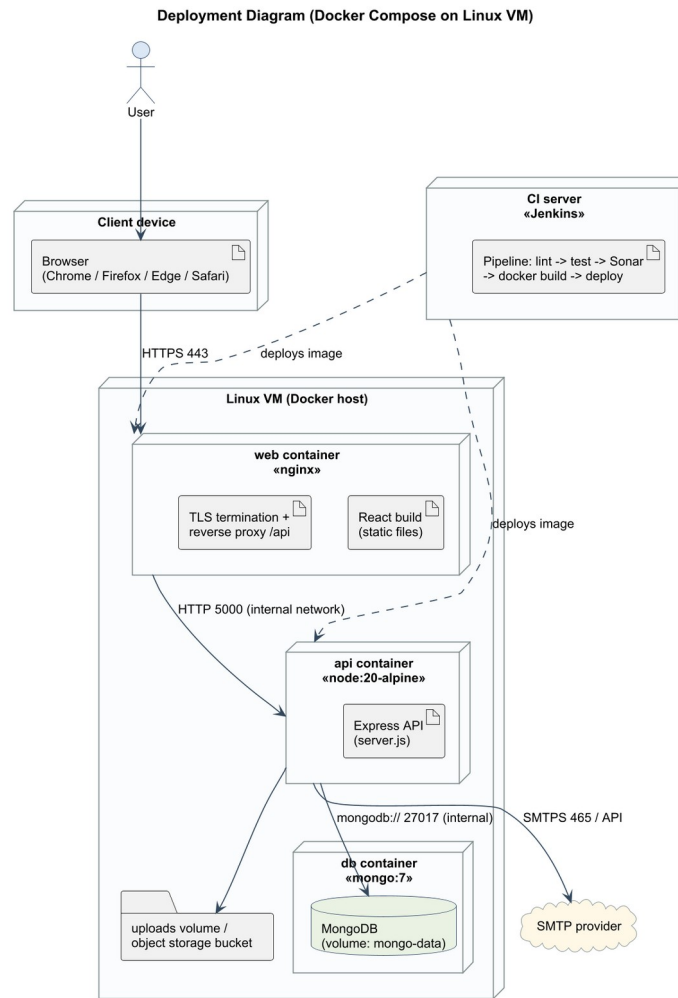


Figure SAD-3: UML deployment diagram

3.6.1 Collections and indexes

Collection	Key fields (types)	Indexes / constraints
users	name String(2–60), email String (lower-case), passwordHash String, role enum, contributor Boolean, timestamps	unique(email)
refresh_tokens	userId ObjectId, tokenHash String (SHA-256), expiresAt Date, revokedAt Date null	unique(tokenHash); TTL on expiresAt
password_resets	userId, tokenHash, expiresAt (30 min), usedAt	unique(tokenHash); TTL on expiresAt
studymaterials	title, description, category, topic, tags[], fileUrl, mimeType, sizeBytes, ownerId, visibility enum, sharedWith[], ratings[{userId, value 1–5}], ratingAvg, hidden Boolean, timestamps	text(title, description, tags); (topic); (ownerId); (visibility, hidden)
comments	materialId, userId, content String(1–1000), timestamps	(materialId, createdAt)
materialrevisions	materialId, versionNo, editorId, title, description, category, topic, tags[], fileUrl, createdAt	unique(materialId, versionNo)
materialreports	materialId, reporterId, reason enum + note, status enum, reviewerId, timestamps	(status, createdAt); partial unique(materialId, reporterId) where status = open
quizzes	title, topic, authorId, status enum, allowRetake Boolean, questions[{_id, text, type, options[], answerKey}], timestamps	(topic, status); (authorId)
attempts	quizId, studentId, answers[{questionId, response, isCorrect}], score,	(quizId, studentId, score desc);

Collection	Key fields (types)	Indexes / constraints
	maxScore, submittedAt	(studentId, submittedAt desc)

3.7 Risks & Mitigations

Risk	Impact	Mitigation
Report abuse: anyone can hide material by reporting it (BR-4)	Medium	One open report per user per material; rate limit on reports; admin queue sorted oldest first; a threshold of N reports is a future enhancement (decision D-1)
Contract drift between owners (e.g. Attempt format used by the leaderboard)	High	API and schemas frozen in this SAD; changes via pull request reviewed by API reviewer; contract tests in CI
Large uploads slow the API	Medium	Streaming upload with 20 MB limit at nginx and multer; files served with range requests
Leaked JWT secret	High	Secrets only in environment variables / Jenkins credentials, never in Git; rotation procedure documented
Demo-day downtime	High	Docker Compose restart policies, health checks, rehearsed redeploy script, database backup before demo
Slow leaderboard aggregation at scale	Low	Compound index on attempts(quizId, studentId, score); results cached for 30 s if needed

3.8 Traceability to Requirements

Requirement(s)	Component(s)	Design element
FR-001–FR-006, SEC-001, SEC-002	C-AUTH, C-GW, C-MAIL	SD-1; API §4.3.2; refresh_tokens, password_resets collections
FR-010–FR-015, FR-018, SEC-006	C-MAT, C-STO, C-GW	SD-2; upload filter; studymaterials, comments, materialrevisions
FR-016, FR-017, BR-4	C-MOD, C-MAT	Report state machine (§4.1); materialreports
FR-020–FR-025, BR-1, SEC-008	C-QUIZ	SD-3; Quiz.isPublishable(), Quiz.toStudentView()
FR-030–FR-033, BR-2, BR-3, NFR-007	C-ATT	SD-4; ScoringService; API §4.3.4
FR-034, FR-035	C-ANL	Aggregation pipelines (§4.1)
SEC-003, SEC-004, SEC-007	C-GW	RBAC matrix (§3.9), validator, ownership guard
SEC-005, NFR-001–NFR-003	Deployment (nginx, Docker)	Deployment diagram; health endpoint
NFR-005, NFR-008	All modules	Layered design, dependency injection, CI pipeline

3.9 Security Architecture

Trust boundaries: (1) browser ↔ nginx over the internet (TLS); (2) nginx ↔ API ↔ MongoDB on the private Docker network (the database port is never published); (3) API ↔ external email and storage providers. All authorisation decisions are made on the server; the UI only hides buttons for convenience.

STRIDE threat	Example in this system	Control
Spooing	Attacker logs in as another user	bcrypt hashes (cost 12); generic login errors; login rate limit 10 / 15 min per IP + email; signed JWT (HS256, 15 min)
Tampering	Student edits the request to send a higher score or change role	Server ignores client score and role fields; schema validation (Zod) with unknown fields stripped; ownership guard
Repudiation	User denies deleting or moderating content	Structured audit log of auth, role, moderation and delete events with userId, requestId and time
Information disclosure	Answer keys or private material leaked	toStudentView() strips answer keys; visibility filter in every

STRIDE threat	Example in this system	Control
		material query; HTTPS + HSTS; no stack traces in responses
Denial of service	Huge uploads or request floods	20 MB limit; JSON body limit 100 kB; rate limiting; pagination capped at 50
Elevation of privilege	Student calls admin or author endpoints	requireRole / canAuthor middleware on every protected route; RBAC matrix tests

3.9.1 Authentication and token design

- Access token: JWT signed with HS256, 15-minute expiry, claims **sub**, **role**, **contributor**; kept in memory by the SPA (not localStorage).
- Refresh token: 256-bit random value in an HttpOnly, Secure, SameSite=Strict cookie scoped to /api/v1/auth; only its SHA-256 hash is stored; 7-day expiry; rotated on every refresh; revoked on logout and on password reset.
- Privilege freshness: requireRole and canAuthor re-read role and contributor from the user record (indexed _id lookup) on every protected request instead of trusting the JWT claims, so an admin grant or revoke (FR-004) takes effect on the next request without waiting for token expiry.
- Passwords: bcrypt with cost 12; password fields are excluded from all queries and logs.

3.9.2 Authorisation (RBAC) matrix

Action	Student	Student + Contributor	Educator	Admin
Browse / search / rate / comment / report material	✓	✓	✓	✓ (no report)
Upload material; create quizzes	✗	✓	✓	✗
Edit / share own material; edit / publish own quiz	✗	✓ (own)	✓ (own)	✓ (any)
Attempt quiz; view own history and dashboard	✓	✓	✗	✗
View leaderboard	✓	✓	✓	✓
Change roles / contributor; review reports	✗	✗	✗	✓

4. Design

4.1 Design Overview

Every backend module uses the same internal structure, so each owner can work alone and services can be unit tested without Express or a real database:

```

server/src/
  app.js           # builds Express app: helmet, cors, json limit, sanitize, routes, errorHandler
  config/          # env loading, logger (pino)
  middleware/      # authenticate, requireRole, canAuthor, ownsResource, validate, upload, rateLimit,
  errorHandler
  modules/
    auth/          auth.routes.js auth.controller.js auth.service.js user.repo.js token.repo.js
  auth.schemas.js
  materials/       material.routes.js ... material.service.js material.repo.js revision.repo.js comment.repo.js
  moderation/     report.routes.js report.service.js report.repo.js
  quizzes/        quiz.routes.js quiz.controller.js quiz.service.js quiz.repo.js quiz.schemas.js
  attempts/       attempt.routes.js attempt.controller.js attempt.service.js scoring.service.js
  attempt.repo.js
  analytics/       progress.service.js leaderboard.service.js analytics.routes.js
  adapters/       storage.js mailer.js
  utils/          AppError.js asyncHandler.js
client/src/       pages/ components/ api/ hooks/ context/AuthContext.jsx

```

4.1.1 Key algorithms

- **Scoring (FR-031):** for each question q in the quiz: $\text{response} = \text{answers}[q_id]$; if response is missing $\rightarrow \text{isCorrect} = \text{false}$ (unanswered); else $\text{isCorrect} = (\text{response} === q.\text{answerKey})$. $\text{score} = \text{count}(\text{isCorrect})$; $\text{maxScore} = \text{number of questions}$. Runs in memory, $O(n)$.
- **Retake rule (BR-2):** if quiz.allowRetake is false and an attempt already exists for $(\text{quizId}, \text{studentId}) \rightarrow 409$ RETAKE_NOT_ALLOWED. A unique partial index cannot express this conditionally, so the check runs in the service and is covered by a race-condition test.
- **Leaderboard (FR-035):** aggregation on attempts: $\$match \text{ quizId} \rightarrow \$group \text{ by studentId with max(score)} \rightarrow \$sort \text{ desc} \rightarrow \text{rank assigned with competition ranking (1, 1, 3) using } \$setWindowFields \$rank$. Topic mode: highest percentage per (student, quiz) over the published quizzes in that topic, then summed per student.
- **Progress (FR-034):** $\$match \text{ studentId} \rightarrow \text{join quizzes for topic} \rightarrow \text{best percentage per quiz} \rightarrow \$group \text{ by topic: quizzesAttempted, averageBestPct; plus a time series of all attempts}$.
- **Revision (FR-015):** before an update, the current metadata and fileUrl are copied into materialrevisions with $\text{versionNo} = \text{last} + 1$; then the material is updated.

4.1.2 State machines

Entity	States	Allowed transitions (actor)
Quiz	draft, published	draft $\rightarrow$ published (author/admin, only if $\text{isPublishable}()$); published $\rightarrow$ draft (author/admin). Edits allowed in both states; editing a published quiz does not change stored attempts.
MaterialReport	open, dismissed, actioned	open $\rightarrow$ dismissed (admin; $\text{material.hidden} = \text{false}$ if no other open report); open $\rightarrow$ actioned (admin; material stays hidden). Final states cannot change.
StudyMaterial.hidden	false, true	false $\rightarrow$ true when a report is opened; true $\rightarrow$ false when the last open report is dismissed.

4.2 UML Sequence Diagrams

Four sequence diagrams cover the most important flows, one per feature owner: SD-1 authentication (Anisha), SD-2 material upload (Aryaroop), SD-3 quiz publishing (Ayush) and SD-4 quiz attempt and scoring (Bharat).

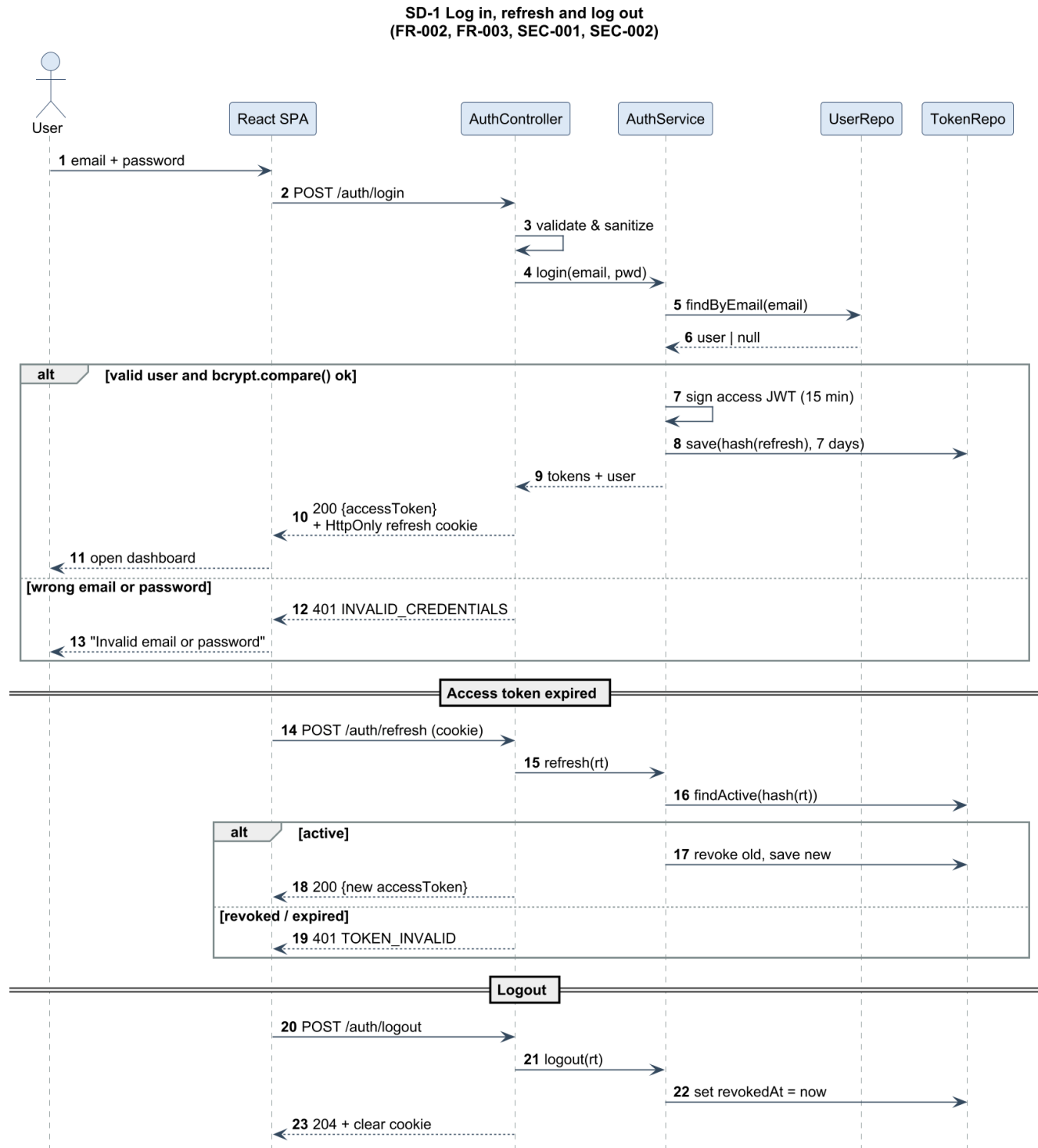


Figure SAD-4: SD-1 Log in, refresh token and log out

SD-2 Upload study material
(FR-010, FR-011, SEC-003, SEC-006)

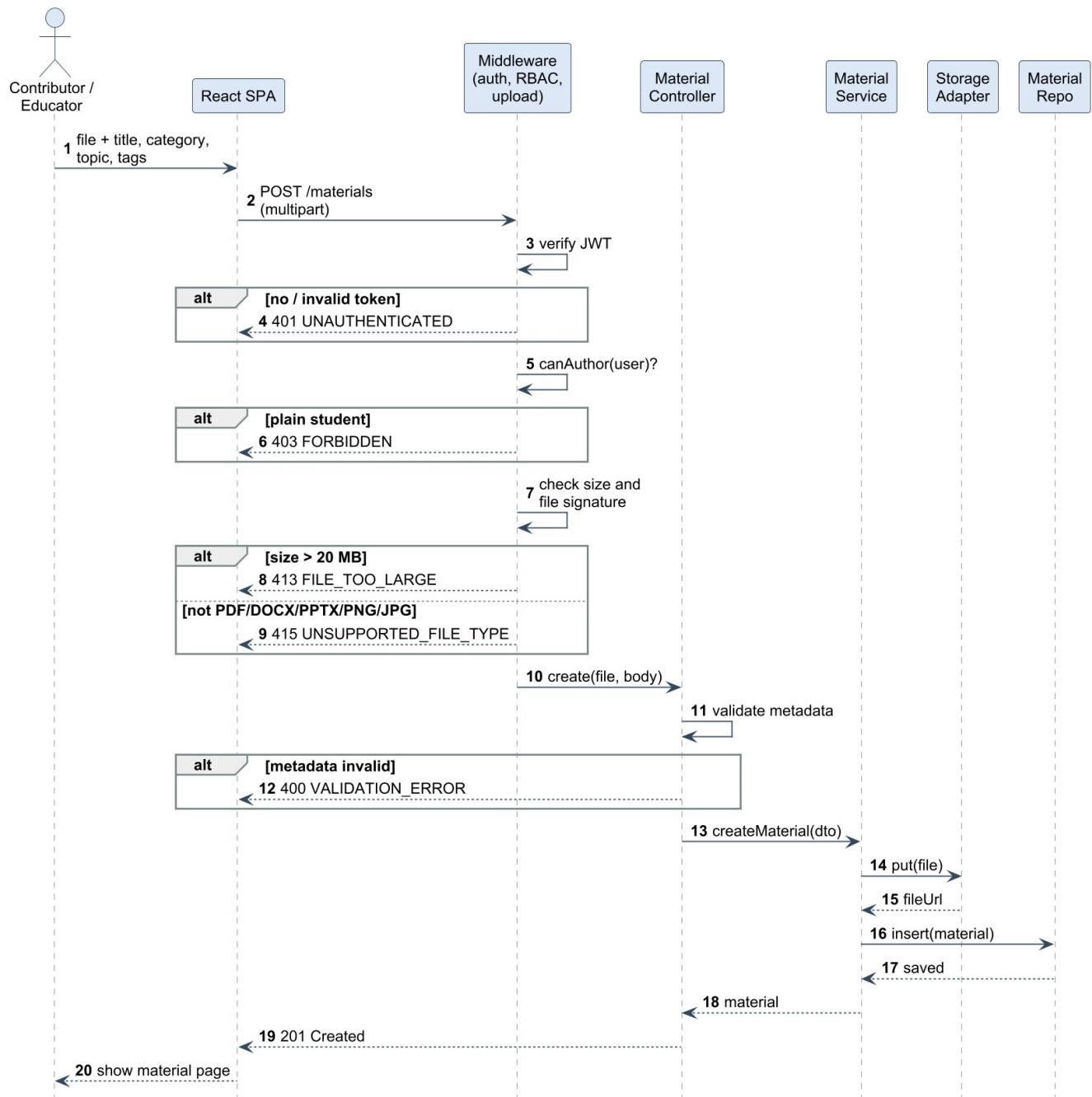


Figure SAD-5: SD-2 Upload study material

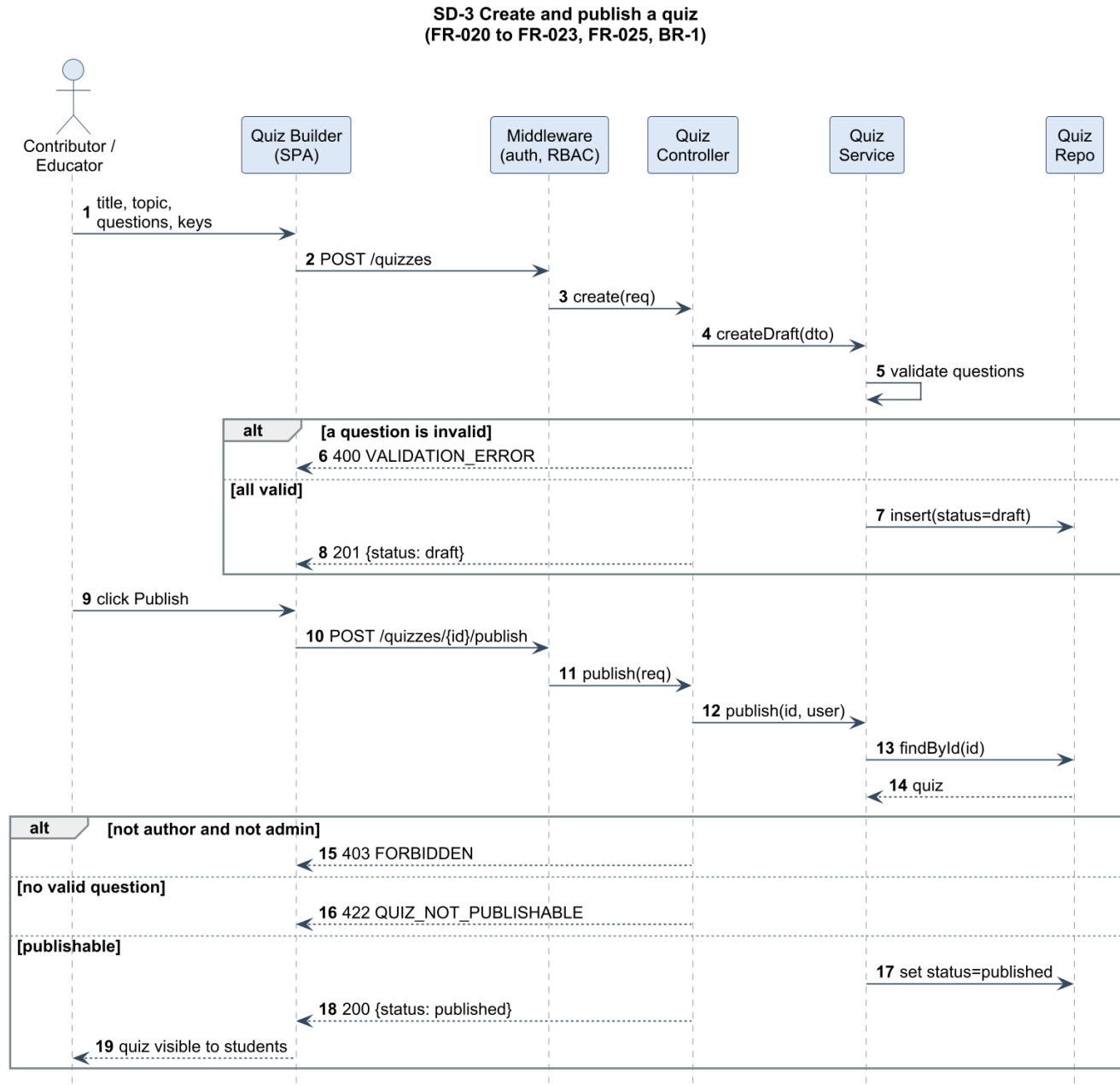


Figure SAD-6: SD-3 Create and publish a quiz

**SD-4 Attempt a quiz with automatic scoring
(FR-030 to FR-033, BR-2, BR-3, SEC-008)**

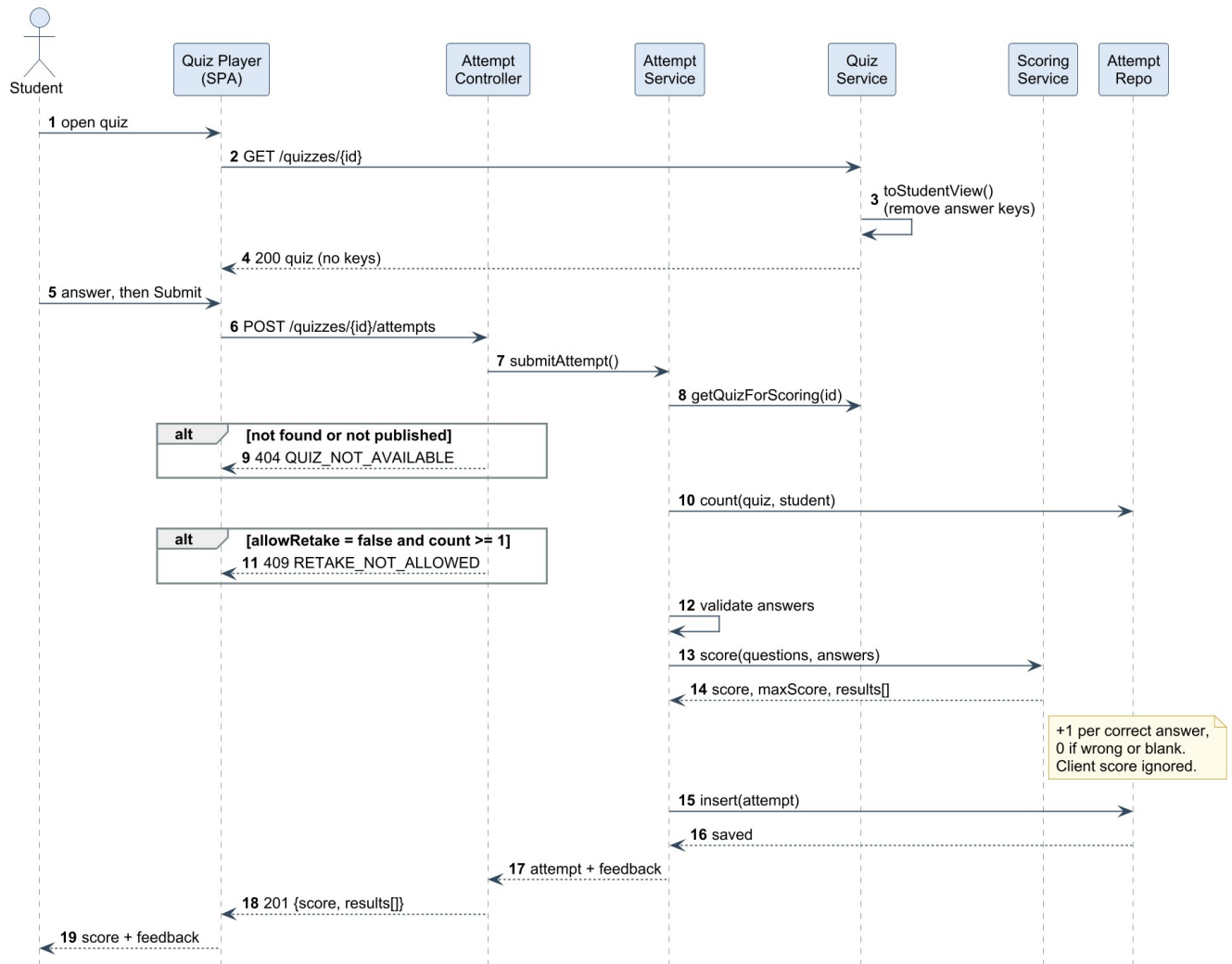


Figure SAD-7: SD-4 Attempt a quiz with automatic scoring

4.3 API Design

4.3.1 Conventions

- Base URL **https://<host>/api/v1**; JSON request/response bodies (UTF-8) except multipart file upload.
- Authentication: **Authorization: Bearer <accessToken>** on every endpoint except register, login, refresh, forgot/reset password and health.
- List endpoints accept **page** (default 1) and **limit** (default 20, max 50) and return **{items, page, limit, total}**.
- Errors use one envelope: **{"error": {"code", "message", "details": [], "requestId"}}** (see §4.4).
- IDs are MongoDB ObjectIds (24 hex chars); invalid IDs return 400. Contracts are versioned by the /v1 prefix and changed only through a reviewed pull request.

4.3.2 Endpoint catalogue

Table SAD-1: REST API endpoint catalogue

Method	Endpoint	Auth / role	Purpose	Req
POST	/auth/register	Public	Create account	FR-001
POST	/auth/login	Public	Get access token + refresh cookie	FR-002
POST	/auth/refresh	Refresh cookie	Rotate refresh token, new access token	FR-002
POST	/auth/logout	Refresh cookie	Revoke refresh token	FR-003
POST	/auth/forgot-password · /auth/reset-password	Public	Email link; set new password	FR-006
GET / PATCH	/users/me	Any user	View / edit own profile	FR-005
GET · PATCH	/admin/users · /admin/users/{id}/role	Admin	List users; set role / contributor	FR-004
POST	/materials	Contributor, Educator	Upload file + metadata (multipart)	FR-010, 011
GET	/materials?q=&tag=&category=&topic=	Any user	Search / filter visible material	FR-012
GET	/materials/{id} · /materials/{id}/file	Any user (visibility)	Detail; download file	FR-012, 013
PATCH	/materials/{id}	Owner, Admin	Edit metadata / file, visibility, sharedWith (creates revision)	FR-013, 015, 018
GET	/materials/{id}/revisions	Owner, Admin	Revision history	FR-015
PUT · GET/POST	/materials/{id}/rating · /materials/{id}/comments	Any user	Rate 1–5; list / add comments	FR-014
POST	/materials/{id}/reports	Student, Contributor, Educator	Report material	FR-016
GET · PATCH	/admin/reports?status=open · /admin/reports/{id}	Admin	Review queue; dismiss / uphold	FR-017
POST · GET	/quizzes · /quizzes?topic=&status=	Author roles · Any user	Create draft; list quizzes	FR-020, 024
GET	/quizzes/{id}	Any user	Quiz detail (no answer keys for students)	FR-030, SEC-008
PUT · DELETE	/quizzes/{id}	Author, Admin	Edit / delete quiz	FR-023
POST	/quizzes/{id}/publish · /unpublish	Author, Admin	Change status	FR-023, 025
POST	/quizzes/{id}/attempts	Student	Submit answers, get score + feedback	FR-030–032
GET	/attempts/me · /attempts/{id}	Student (own)	Attempt history / detail	FR-033
GET	/analytics/me/progress	Student	Progress dashboard data	FR-034
GET	/leaderboard?quizId= ?topic=	Any user	Ranked students	FR-035
GET	/health	Public	Liveness / readiness for monitoring	NFR-003

The request/response bodies below are illustrative examples: IDs are truncated and names, emails and values are sample data.

4.3.3 Auth component — POST /api/v1/auth/login

```
Request: {"email": "student1@pes.edu", "password": "S3curePass"}
200 OK: {"accessToken": "<jwt>", "expiresIn": 900,
        "user": {"id": "66f1...", "name": "Riya", "role": "student", "contributor": false}}
Set-Cookie: rt=<opaque>; HttpOnly; Secure; SameSite=Strict; Path=/api/v1/auth; Max-Age=604800
Errors: 400 VALIDATION_ERROR (bad email format / missing field)
        401 INVALID_CREDENTIALS (same message for unknown email and wrong password)
        429 RATE_LIMITED (more than 10 attempts in 15 min)
```

4.3.4 Attempt component — POST /api/v1/quizzes/{quizId}/attempts

```
Auth: Bearer token, role = student (contributor allowed)
Request: {"answers": [{"questionId": "q1", "response": 2},
                    {"questionId": "q2", "response": true},
                    {"questionId": "q3", "response": null}]} // null or missing = unanswered
201 Created: {"attemptId": "6701...", "score": 1, "maxScore": 3, "percentage": 33.3,
              "submittedAt": "<ISO-8601 UTC timestamp>",
              "results": [{"questionId": "q1", "isCorrect": true, "correctAnswer": 2},
                          {"questionId": "q2", "isCorrect": false, "correctAnswer": false},
                          {"questionId": "q3", "isCorrect": false, "unanswered": true, "correctAnswer":
1}}}
Errors: 400 VALIDATION_ERROR (unknown questionId, wrong response type, duplicate questionId)
        401 UNAUTHENTICATED 403 FORBIDDEN (educator/admin)
        404 QUIZ_NOT_AVAILABLE (missing, draft or unpublished) 409 RETAKE_NOT_ALLOWED
```

4.3.5 Quiz component — POST /api/v1/quizzes and POST /api/v1/quizzes/{id}/publish

```
Request (create):
{"title": "DBMS Normalisation Basics", "topic": "dbms", "allowRetake": true,
 "questions": [{"text": "Which normal form removes partial dependency?", "type": "mcq",
                 "options": ["1NF", "2NF", "3NF", "BCNF"], "answerKey": 1},
               {"text": "BCNF is stricter than 3NF.", "type": "true_false", "answerKey": true}]}
201 Created: {"id": "6702...", "status": "draft", ...}
POST /quizzes/{id}/publish -> 200 {"id": "6702...", "status": "published"}
Errors: 400 VALIDATION_ERROR (MCQ options not 2-6, answerKey out of range, unknown type)
        403 FORBIDDEN (not author/admin) 422 QUIZ_NOT_PUBLISHABLE (no valid question)
GET /quizzes/{id} as a student returns questions WITHOUT the answerKey field (SEC-008).
```

4.3.6 Material component — POST /api/v1/materials (multipart/form-data)

```
Fields: file (PDF|DOCX|PPTX|PNG|JPG, <= 20 MB), title, description, category, topic,
        tags (comma-separated, max 10), rightsConfirmed=true (BR-5)
201 Created: {"id": "6703...", "title": "...", "visibility": "private", "fileUrl":
"/api/v1/materials/6703.../file"}
Errors: 400 VALIDATION_ERROR 401 UNAUTHENTICATED 403 FORBIDDEN (no authoring rights)
        413 FILE_TOO_LARGE 415 UNSUPPORTED_FILE_TYPE
```

4.4 Error Handling, Logging & Monitoring

Controllers never build error responses themselves. Services throw typed **AppError** subclasses; an **asynchHandler** wrapper forwards them to one central **errorHandler** middleware, which maps them to the envelope below.

Unknown errors become 500 INTERNAL_ERROR with a generic message; the stack trace is logged, never returned.

HTTP	Error code	When
400	VALIDATION_ERROR	Body, query or ID fails schema validation; details[] lists field errors for inline display
401	UNAUTHENTICATED / INVALID_CREDENTIALS / TOKEN_INVALID	Missing or bad token; wrong login; revoked or expired refresh token
403	FORBIDDEN	Role, privilege or ownership check fails
404	NOT_FOUND / QUIZ_NOT_AVAILABLE	Resource missing or not visible to the caller (private items are reported as 404, not 403)
409	EMAIL_TAKEN / RETAKE_NOT_ALLOWED / REPORT_EXISTS	Uniqueness or business-rule conflict
413 / 415	FILE_TOO_LARGE / UNSUPPORTED_FILE_TYPE	Upload rules (SEC-006)
422	QUIZ_NOT_PUBLISHABLE	Publish gate (FR-025)
429	RATE_LIMITED	Too many requests (login, reports, global limit)
500	INTERNAL_ERROR	Unexpected failure

- **Logging:** pino JSON logs with timestamp, level, requestId, userId, method, route, status and latency. Passwords, tokens, answer keys and file contents are redacted. Audit events: login success/failure, logout, role change, report decisions and deletes.
- **Client:** the Axios interceptor refreshes the access token once on 401 TOKEN_EXPIRED, then retries; field errors appear inline; other errors show a toast with the requestId.
- **Monitoring:** `/api/v1/health` checks the process and database connection (used by Docker health checks and the uptime probe for NFR-003); dashboards track 5xx rate, p95 latency and failed logins.

4.5 UX Design

- **Navigation by role:** students see Library, Quizzes, My Progress and Leaderboard; contributors and educators also see Upload and My Quizzes; admins see the Admin Console (Users, Reports).
- **Quiz player:** one question per card with progress (“Question 3 of 10”), previous/next, a review screen that highlights unanswered questions, and a confirm dialog before submit. Results show green/red marks per question with the correct answer.
- **Forms:** inline validation as the user types (React Hook Form + Zod, using the same rules as the API), clear required-field markers, and disabled submit while a request is in progress.
- **Accessibility & responsiveness:** keyboard navigation, visible focus, labels on every input, colour contrast at WCAG 2.1 AA, layouts that work from 360 px phones to desktop.

4.6 Design Decisions & Planned Work

Questions left open during design are resolved below for release 1.0. Items marked Planned are scheduled tasks, not unresolved design questions.

ID	Topic	Decision / plan for release 1.0	Status	Owner
D-1	Report abuse (BR-4)	Keep BR-4: one open report hides the material until an administrator reviews it, with the mitigations in §3.7 (one open report per user, rate limit, oldest-first queue). Hiding only after N reports is a future enhancement, not part of this release.	Decided	Aryaroop
D-2	File storage	Docker volume behind the storage adapter (C-STO). An S3-compatible bucket can replace it later without changing callers.	Decided	Aryaroop
D-3	Editing a published quiz	No quiz versioning in this release. Each attempt stores its own answers, isCorrect flags, score and maxScore when submitted, so history, dashboard and leaderboard stay valid after later edits.	Decided	Ayush
P-1	API contract file	Export the endpoint catalogue in §4.3 as a Postman collection in Sprint	Planned	Anisha

ID	Topic	Decision / plan for release 1.0	Status	Owner
		2 and run it as contract tests in CI.		
P-2	Implementation	Sprints 2–5 per the synopsis plan; this SAD is updated through a reviewed pull request whenever the design changes.	Planned	All

5. Appendices

5.1 Glossary: see SRS §1.4 and §1.4 of this document.

5.2 References: ISO/IEC/IEEE 42010 (architecture description); OWASP Top 10 2021; OWASP ASVS 4.0; RFC 7519 (JWT); MongoDB data-modelling guidance.

5.3 Tools: PlantUML (all UML diagrams in this document). API documentation will be kept as a Postman collection (planned, P-1).

Software Test Plan (STP)

Collaborative Study Material & Quiz Platform

Field	Details
Project	Collaborative Study Material & Quiz Platform
Version	1.0
Authors	Anisha Nukul Niranjan, Aryaroop Bose, Ayush Ravindra Paithankar, Bharat V Bhat (Team Lead) — QA coordination: Bharat V Bhat
Date	02-10-2026
Status	Baselined for Submission (Deliverables Part-1)

1. Introduction

Purpose: This document defines the test plan for software release 1.0 of the Collaborative Study Material & Quiz Platform (document version STP v1.0): objectives, scope, strategy, environment, schedule, responsibilities, test cases and traceability to SRS v1.2.

Scope: Testing covers all four features — accounts & authentication, study material & moderation, quiz creation & leaderboard, quiz attempts, scoring & analytics — plus the non-functional and security requirements. Third-party internals (MongoDB engine, email provider, browsers) are excluded.

References: SRS v1.2 and SAD v1.0 (this submission); IEEE Std 829-2008 / ISO/IEC/IEEE 29119-3 (test documentation); OWASP Top 10 2021; OWASP Web Security Testing Guide.

Definitions: BVA (Boundary Value Analysis), EP (Equivalence Partitioning), E2E (end-to-end), IDOR (Insecure Direct Object Reference), RTM, SUT (System Under Test), UAT (User Acceptance Test), VU (virtual user).

2. Test Items

Test item	Component (SAD)	Software build
Auth & User module (registration, login, tokens, profile, roles, password reset)	C-AUTH, C-MAIL	server v1.0
Study Material module (upload, tags, search, visibility, ratings, comments, revisions)	C-MAT, C-STO	server v1.0
Moderation module (reports, admin review)	C-MOD	server v1.0
Quiz module (authoring, validation, publish gate, student view)	C-QUIZ	server v1.0
Attempt & Scoring module (submit, scoring, feedback, history)	C-ATT	server v1.0
Analytics & Leaderboard module	C-ANL	server v1.0
Security & request pipeline (auth, RBAC, validation, upload filter, errors)	C-GW	server v1.0
React SPA (all pages)	C-UI	client v1.0
Deployment (nginx TLS, Docker Compose)	Deployment view	compose v1.0

3. Features to be Tested

Features mapped to SRS requirement IDs:

Feature	SRS requirement IDs	Priority	Owner (tester)
Registration, login, logout, password reset	FR-001, FR-002, FR-003, FR-006	High	Anisha
Roles, contributor privilege, profile	FR-004, FR-005	High	Anisha
Upload, tags, search, visibility	FR-010, FR-011, FR-012, FR-013	High	Aryaroop
Ratings, comments, revisions, metadata edit	FR-014, FR-015, FR-018	Medium	Aryaroop
Reporting and moderation	FR-016, FR-017	Medium	Aryaroop
Quiz authoring, validation, publish gate, topic link	FR-020 – FR-025	High	Ayush
Leaderboard	FR-035	Low	Ayush
Quiz attempt, scoring, feedback, history	FR-030 – FR-033	High	Bharat
Progress dashboard	FR-034	Medium	Bharat
Performance, scalability, availability	NFR-001, NFR-002, NFR-003	High	Bharat
Usability, portability	NFR-004, NFR-006	Medium	Aryaroop
Maintainability, reliability, testability	NFR-005, NFR-007, NFR-008	High	Bharat
Security requirements	SEC-001 – SEC-008	High	All (coordinated by Bharat)

4. Features Not to be Tested

- Internal behaviour of MongoDB, Node.js, React and other third-party libraries (assumed tested by their vendors; covered only through our integration tests).
- Email deliverability of the real SMTP provider (a mail stub captures messages in test).
- Out-of-scope features listed in SRS §1.2 (payments, live streaming, AI grading, native mobile apps, ERP integration).
- Load above 100 concurrent users and multi-region failover (not required by NFR-002 / NFR-003).

5. Test Approach / Strategy

Levels:

Level	What is tested	Tools	Responsibility	When
Unit	Services and pure functions (scoring, validation, ranking, revision snapshot) with repositories mocked	Jest	Each module owner	Every commit (CI)
Integration	API routes + middleware + MongoDB (in-memory) through HTTP	Jest + Supertest + mongodb-memory-server	Each module owner; API reviewer	Every pull request (CI)
System / E2E	Full stack in Docker via the browser and API	Playwright, Postman/Newman	QA coordinator + owners	End of each sprint
Acceptance (UAT)	User tasks against acceptance criteria; usability sessions	Scripts, observation sheet	Team + faculty	Sprint 6

Types: functional (positive and negative), regression (full automated suite on every merge to main), performance and load (k6), security (§5.1), usability (moderated sessions), compatibility (Playwright on Chrome, Edge, Firefox and WebKit, plus manual Safari where available), reliability (restart and concurrency tests), static analysis (SonarQube, ESLint).

Test design techniques: equivalence partitioning and boundary value analysis for input limits (password length, MCQ options 2–6, rating 1–5, file size 20 MB); decision tables for the RBAC matrix and the retake rule; state-transition testing for quiz status and report status; error guessing for injection and IDOR.

CI pipeline (Jenkins): checkout → npm ci → ESLint → unit tests → integration tests → coverage report (fail below 70 % on core modules) → SonarQube scan + quality gate → npm audit (fail on high) → docker build → deploy to staging → Newman API smoke → Playwright smoke.

Entry criteria: build compiles and passes lint; feature merged through a reviewed pull request; test data seeded; environment healthy (/health OK).

Exit criteria: 100 % of planned test cases executed; 100 % of High-priority cases passed; no open Critical or High defects; NFR-001/002/005 targets met; every requirement in the RTM linked to at least one passed test.

Defect severity: Critical — data loss, security breach or system down; High — a main feature fails with no workaround; Medium — feature fails with a workaround; Low — cosmetic. Defects are logged as GitHub/Jira issues linked to the test case and requirement.

5.1 Security Validation

Area	Validation activity	Tool / method	Req	Test
Credential storage	Check bcrypt hashes in DB; search logs for known passwords and tokens	Mongo shell, grep, code review	SEC-001	TC-SEC-01
Session / token handling	Expired, tampered and alg=none JWTs; refresh after logout; cookie flags	Supertest, jwt.io, browser dev tools	SEC-002	TC-SEC-02, TC-AUTH-06
Authorisation	Automated role × endpoint matrix; privilege escalation attempts	Jest table-driven tests	SEC-003	TC-SEC-03, TC-AUTH-07
Injection & XSS	NoSQL operator injection, script payloads in all text fields, fuzzing of query params	Supertest, OWASP ZAP active scan	SEC-004	TC-SEC-04
Transport security	Protocol versions, cipher suites, HTTP→HTTPS redirect, HSTS	testssl.sh / sslscan, curl	SEC-005	TC-SEC-05
File upload	Type spoofing, oversized files, polyglot and SVG files	Crafted test files	SEC-006	TC-SEC-06
Object-level access (IDOR)	Change IDs in URLs to other users' material, quizzes and attempts	Postman, ZAP	SEC-007	TC-SEC-07, TC-ATT-08
Assessment integrity	Look for answer keys in responses before submit; send fake scores	Browser network tab, Supertest	SEC-008, FR-031	TC-SEC-08, TC-ATT-06
Dependencies & code	Known-vulnerable packages; security hotspots	npm audit, SonarQube	NFR-005	TC-MNT-01

Penetration test plan: in Sprint 5, run an OWASP ZAP baseline (passive) scan on every staging deploy and one authenticated active scan against staging, followed by a manual session that follows the OWASP Top 10 2021 categories that apply (A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A05 Security Misconfiguration, A07 Identification & Authentication Failures). Findings are logged as defects with severity, fixed, and re-tested before release.

6. Test Environment

- **Hardware:** team laptops (8 GB+ RAM) for development; one Linux VM (2 vCPU, 4 GB RAM) as staging/demo host; Jenkins agent.
- **Software:** Node.js 20, MongoDB 7, Docker Compose stack (nginx, api, mongo) identical to production; Google Chrome and Microsoft Edge (Playwright branded channels), Firefox and WebKit via Playwright; real Safari on a Mac / iPhone for manual checks where available.
- **Tools:** Jest, Supertest, mongodb-memory-server, React Testing Library, Playwright, Postman/Newman, k6, OWASP ZAP, testssl.sh, SonarQube, Jenkins, GitHub Issues / Jira for defects.
- **Tool status:** Git/GitHub, Jira / GitHub Projects, Jenkins, Docker, Jest, SonarQube and Postman are the committed project toolchain (Synopsis §10). Playwright, k6, OWASP ZAP and testssl.sh are planned additions for

system, performance and security testing. No test has been executed yet; evidence for every tool will be attached to the Test Summary Report.

- **Test data:** seed script creating 4 role accounts (student, contributor, educator, admin) plus 100 load-test students, 30 materials across 5 topics (public / shared / private / hidden), 10 quizzes (draft and published, retake on/off) and sample attempts. No real student data is used.

7. Test Schedule

Aligned to the synopsis sprint plan (dates are planned and will be updated in each sprint review):

Milestone	Planned date	Output
Test plan and test case design (this document)	02-Oct-2026	STP v1.0
CI pipeline + test environment setup (Jenkins, Docker, seed data)	10-Oct-2026	Green pipeline on main
Unit + integration testing per sprint (Sprints 2–5)	12-Oct-2026 to 15-Nov-2026	CI reports, coverage
System / E2E and cross-browser testing	16-Nov-2026 to 21-Nov-2026	Execution log
Security validation and performance testing	16-Nov-2026 to 24-Nov-2026	ZAP, k6 and TLS reports
UAT and usability sessions; regression	25-Nov-2026 to 28-Nov-2026	UAT sign-off
Test summary report	30-Nov-2026	Final validation report

8. Test Deliverables

- Test Plan (this document) and Test Cases (§13.1), kept up to date each sprint.
- Automated test scripts (Jest, Supertest, Playwright, k6, Newman collection) in the repository.
- Test data seed scripts.
- Test execution logs and CI reports (unit, integration, coverage, SonarQube).
- Security reports (ZAP, npm audit, TLS scan) and defect reports.
- Test Summary / Validation Report with the completed RTM (Actual Result and Pass/Fail filled in).

9. Roles and Responsibilities

Role	Name	Responsibility
QA Lead / Test coordinator	Bharat V Bhat	Owens this plan, CI test stages, performance and reliability tests, test summary report; tests SF-4
Test Engineer — Accounts & security	Anisha Nukul Niranjan	Designs and runs TC-AUTH and auth-related TC-SEC cases; API contract review
Test Engineer — Material, moderation & UX	Aryaroop Bose	TC-MAT, TC-MOD, TC-UX, TC-PORT; usability sessions
Test Engineer — Quiz & data	Ayush Ravindra Paithankar	TC-QZ, TC-LB; seed data and database checks
Developers (all)	Module owners	Write unit/integration tests with their code; fix and triage defects
Product Owner / Approver	Dr Sapna V M (Course faculty)	Reviews results and approves readiness

10. Risks and Mitigation

Risk	Mitigation
Features finish late, leaving little time for testing	Tests written with each feature in the same pull request; CI blocks merges

Risk	Mitigation
	without tests
Shared staging VM goes down	Docker Compose can be started on any laptop; nightly DB dump
Contract changes break other modules	Integration and contract tests in CI; API reviewer approval required
Limited load-test hardware	Run k6 from a separate machine; scale VUs gradually; record environment details
Not enough first-time users for usability test	Recruit 5 classmates from other teams early in Sprint 5

11. Assumptions & Dependencies

- A staging VM with Docker and a TLS certificate (or self-signed certificate for internal testing) is available by 10-Oct-2026.
- Jenkins and SonarQube instances are reachable from the repository.
- Each module owner delivers unit tests with their code; the seed script is kept in sync with schema changes.
- The email service is replaced by a stub in automated tests.

12. Suspension & Resumption Criteria

Suspend testing if: the staging environment is unavailable for more than 4 hours; the build blocks more than 30 % of planned test cases; a Critical security defect is found (stop the release until fixed).

Resume testing when: blocking defects are fixed and verified; the environment passes the health check and smoke suite; the regression suite is re-run on the new build.

13. Test Case Management & Traceability

The plan contains **121 test cases**: 13 unit, 81 integration, and the rest system, performance, reliability, acceptance, static and security tests. Every FR, NFR and SEC requirement has at least one test case, and every use case has at least 8 (§13.3). Test cases are versioned in the repository (test-cases.xlsx) and as automated scripts; Actual Result and Status are filled in when each case is executed.

13.1 Test cases

Table STP-1: Test cases (Actual result and Pass/Fail are recorded on execution)

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-AUTH-01	FR-001	Integration	Register with valid details	Email not registered	POST /auth/register	name "Riya S", email riya@pes.edu, pwd "Passw0rd"	201; role = student, contributor = false; passwordHash starts with \$2b\$		Not run
TC-AUTH-02	FR-001	Integration	Reject duplicate email (negative)	riya@pes.edu exists	Register again with same email (upper-case variant)	RIYA@pes.edu	409 EMAIL_TAKEN; no second user stored		Not run
TC-AUTH-03	FR-001	Unit (BVA)	Password and name boundaries	—	Validate schema with boundary values	pwd 7 chars / 8 chars; "abcdefgh" (no digit); name 1 / 2 / 60 / 61 chars	7 chars, no digit, name 1 or 61 → 400; 8-char "Passw0rd", name 2 and 60 → valid		Not run
TC-AUTH-04	FR-002	Integration	Login with correct credentials	User exists	POST /auth/login	riya@pes.edu / Passw0rd	200; JWT exp – iat = 900 s; refresh cookie HttpOnly, Secure, SameSite=Strict		Not run
TC-AUTH-05	FR-002	Integration	Login with wrong password / unknown email (negative)	User exists	Login twice with bad inputs	wrong pwd; nobody@pes.edu	Both 401 INVALID_CREDENTIALS with identical message		Not run
TC-AUTH-06	FR-003, SEC-002	Integration	Logout revokes refresh token	Logged in	POST /auth/logout → POST /auth/refresh with old cookie	Old refresh token	Logout 204; refresh 401 TOKEN_INVALID		Not run
TC-AUTH-07	FR-004, SEC-003	Integration	Student blocked from admin endpoint	Student token	PATCH /admin/users/{id}/role	{"role": "admin"}	403 FORBIDDEN; role unchanged		Not run
TC-AUTH-08	FR-004	System	Admin grants contributor privilege	Admin + student accounts	Admin sets contributor = true → student uploads a PDF	Valid 1 MB PDF	Grant 200; upload 201 (was 403 before grant)		Not run
TC-AUTH-09	FR-005	Integration	Edit own profile; cannot change role	Student logged in	PATCH /users/me twice	{"name": "Riya Sharma"}; {"role": "admin"}	First 200 with new name; second 400; stored role still student		Not run
TC-AUTH-10	FR-006	Integration	Password reset link is single-use and expires	User exists; mail stub	Forgot → reset with token → reuse token → reset with 31-min-old token	New pwd "NewPassw0rd"	Reset 200; old pwd fails, new works; reuse 400; expired 400; old refresh tokens revoked		Not run
TC-AUTH-11	FR-004	System	Admin revokes contributor privilege (negative)	Admin + student with contributor = true; student holds an access token issued before the revoke	Admin sets contributor = false → student uploads a PDF with the same (still unexpired) token	Valid 1 MB PDF	Revoke 200; upload 403 FORBIDDEN; nothing stored (no DB record, no file on volume)		Not run
TC-AUTH-12	FR-002	Integration	Refresh rotates the token	Logged in; valid refresh cookie	POST /auth/refresh → reuse the old cookie	Current refresh cookie	First call 200 with new access token and new cookie; reuse of old cookie → 401 TOKEN_INVALID		Not run
TC-AUTH-13	FR-002	Integration	Login rate limit (negative)	User exists	Send 11 wrong-password logins within 15 min from one IP	riya@pes.edu / wrong pwd × 11	Attempts 1–10 → 401; attempt 11 → 429 RATE_LIMITED; correct login after the window → 200		Not run
TC-AUTH-14	FR-005	Integration	View own profile	Student logged in	GET /users/me	—	200 with name, email, role, contributor; no passwordHash or token fields in the JSON		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-AUTH-15	FR-005	Unit (BVA)	Profile name boundaries	—	Validate profile schema	name 1 / 2 / 60 / 61 chars	1 and 61 → invalid; 2 and 60 → valid		Not run
TC-AUTH-16	FR-005	Integration	Cannot change email or contributor via profile (negative)	Student logged in	PATCH /users/me twice	{"email":"x@pes.edu"; {"contributor":true}	Both 400 VALIDATION_ERROR; stored email and contributor unchanged		Not run
TC-AUTH-17	FR-005	Integration	Profile requires a valid token (negative)	—	GET and PATCH /users/me without a token	—	401 UNAUTHENTICATED for both; nothing changed		Not run
TC-AUTH-18	FR-005	Integration	Operator and script input in name (negative)	Student logged in	PATCH /users/me twice; open profile page	{"name":{"\$gt":""}}; name "<script>alert(1)</script>"	Object → 400 VALIDATION_ERROR; script name shown as plain text, no script runs		Not run
TC-AUTH-19	FR-005	Integration	Empty profile update (negative)	Student logged in	PATCH /users/me with empty body	{}	400 VALIDATION_ERROR; profile unchanged		Not run
TC-AUTH-20	FR-005	System	Edit profile in the UI	Student logged in	Profile page → type 1-char name → then valid name → save → reload	"R"; "Riya Sharma"	Inline error before submit for "R"; after save and reload header shows "Riya Sharma"		Not run
TC-AUTH-21	FR-004	Integration	Admin changes role to educator	Admin + student accounts	PATCH /admin/users/{id}/role → user creates a quiz → user attempts a quiz	{"role":"educator"}	200; quiz create 201; attempt 403 (educators cannot attempt)		Not run
TC-AUTH-22	FR-004	Integration	Invalid role or privilege value (negative)	Admin logged in	PATCH /admin/users/{id}/role twice	{"role":"superuser"; {"contributor":"yes"}	Both 400 VALIDATION_ERROR; stored role and contributor unchanged		Not run
TC-AUTH-23	FR-004	Integration	Admin lists users	Admin; 4 seeded accounts	GET /admin/users as admin, then as student	—	Admin 200 with role and contributor per user, no passwordHash; student 403		Not run
TC-AUTH-24	FR-004	Integration	Unknown or malformed user ID (negative)	Admin logged in	PATCH /admin/users/{id}/role	Random valid ObjectId; "abc"	404 NOT_FOUND; 400 VALIDATION_ERROR		Not run
TC-AUTH-25	FR-004	Integration	Role change applies on the next request	Educator E holds an unexpired access token	Admin sets E to student → E creates a quiz with the same token	Valid quiz body	Role change 200; quiz create 403 FORBIDDEN (role re-read from DB, not the JWT)		Not run
TC-MAT-01	FR-010, FR-011	Integration	Contributor uploads material with tags	Contributor logged in	POST /materials (multipart)	2 MB PDF; title "ER Diagrams"; category Notes; topic dbms; tags "ER, dbms, ER"	201; visibility private; tags stored ["er", "dbms"]		Not run
TC-MAT-02	FR-010	Integration	Plain student cannot upload (negative)	Student (no contributor)	POST /materials	Valid PDF	403 FORBIDDEN; nothing stored		Not run
TC-MAT-03	FR-010	Integration	Required metadata missing (negative)	Contributor	Upload without title; with 2-char title	title "" / "ab"	400 VALIDATION_ERROR naming field title		Not run
TC-MAT-04	FR-012	Integration	Search with keyword + tag filter	5 seeded items (1 private, 1 hidden)	GET /materials? q=normalisation&tag=dbms	—	Only visible items matching both filters; private and hidden items absent; page size 20		Not run
TC-MAT-05	FR-013	Integration	Visibility private / shared / public	Owner A, users B and C	Set shared with B → B and C fetch; set public → C fetches	sharedWith=[B]	Shared: B 200, C 404; public: C 200		Not run
TC-MAT-06	FR-014	Integration	Rate and comment;	Public material	PUT rating 4, then 2 by same	value 4→2, 0, 6; comment	One rating stored (2); 0 and 6 →		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
			rating bounds		user; rate 0 and 6; add comment	"Helpful"	400; comment stored as separate document		
TC-MAT-07	FR-015, FR-018	Integration	Owner edit creates revision	Material v0 by owner	PATCH title and tags	title "ER Diagrams v2"	200; revision versionNo 1 holds old title and tags; list newest first		Not run
TC-MAT-08	FR-018, SEC-007	Integration	Non-owner cannot edit (negative)	Material owned by A; B is a contributor	B sends PATCH /materials/{id}	{"title":"hacked"}	403; no revision created; admin doing the same → 200		Not run
TC-MAT-09	FR-010	Integration	Educator uploads study material	Educator logged in (role = educator, contributor = false)	POST /materials (multipart)	2 MB PDF; title "Normal Forms"; category Notes; topic dbms	201; ownerId = educator; visibility private; material listed for its owner		Not run
TC-MAT-10	FR-010	Integration	Rights confirmation required (negative)	Contributor logged in	POST /materials without rightsConfirmed (BR-5)	Valid PDF; rightsConfirmed missing / false	400 VALIDATION_ERROR naming rightsConfirmed; nothing stored		Not run
TC-MAT-11	FR-011	Unit (BVA)	Tag count and length boundaries	—	Validate tags	0, 1, 10, 11 tags; tag of 30 / 31 chars	0, 11 tags and 31 chars → invalid; 1, 10 tags and 30 chars → valid		Not run
TC-MAT-12	FR-010	Unit (BVA)	Title, category and topic rules	—	Validate material metadata	title 3 / 120 / 121 chars; category or topic missing	3 and 120 → valid; 121 → invalid; missing category or topic → invalid		Not run
TC-MAT-13	FR-012	Integration	Filter by category	8 visible items: 5 Notes, 3 Slides	GET /materials?category=Notes	—	Exactly the 5 Notes items		Not run
TC-MAT-14	FR-012	Integration (BVA)	Pagination at 20 per page	45 visible items	GET /materials?page=1, 2, 3, 4	—	20, 20, 5 and 0 items; total = 45 in every response		Not run
TC-MAT-15	FR-012	Integration	Search with no matches	Seeded material	GET /materials?q=xyzy	—	200 with empty list and total 0; UI shows "No material found"		Not run
TC-MAT-16	FR-012	Integration	Operator in query parameter (negative)	Seeded material incl. private items	GET /materials?tag[\$ne]=x	—	400 VALIDATION_ERROR; no unfiltered or private items returned		Not run
TC-MAT-17	FR-013	Integration	Private item hidden from detail and download	Private material owned by A	B calls GET /materials/{id} and /materials/{id}/file; then A does the same	—	B: 404 for both; A: 200 for both		Not run
TC-MAT-18	FR-012, FR-013	Integration	Shared item appears in search only for listed users	Material shared with B; C not listed	B and C search by its title	—	B sees the item; C does not		Not run
TC-MAT-19	FR-012	System (E2E)	Search and open material in the UI	Seeded material	Library → keyword + tag filter → open detail → download	"normalisation", tag dbms	Results update without reload; detail shows file, average rating and comments; download succeeds		Not run
TC-MAT-20	FR-014	Unit	Average rating calculation	—	Compute ratingAvg; then one user re-rates	Ratings 5, 4, 2; re-rate 2 → 5	ratingAvg 3.67, then 4.67		Not run
TC-MAT-21	FR-014	Unit (BVA)	Comment length boundaries	—	Validate comment	0 / 1 / 1000 / 1001 chars	0 and 1001 → invalid; 1 and 1000 → valid		Not run
TC-MAT-22	FR-014	Integration	Non-integer rating (negative)	Public material	PUT /materials/{id}/rating twice	value 3.5; value "four"	Both 400 VALIDATION_ERROR; no rating stored		Not run
TC-MAT-23	FR-014, FR-013	Integration	Cannot rate or comment on hidden-from-me material (negative)	Private material owned by A	B rates and comments	value 4; "Nice"	404 for both; nothing stored		Not run
TC-MAT-24	FR-014	Integration	List comments	Public material with 3 comments	GET /materials/{id}/comments	—	3 items, each with author, content and createdAt, ordered by		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
							createdAt		
TC-MAT-25	FR-014	System	Rate and comment in the UI	Public material; student logged in	Click 4 stars; post a comment; try an empty comment	"Very clear notes"	Average and new comment appear without reload; empty comment shows inline error		Not run
TC-MAT-26	FR-015	Integration	Several edits give sequential revisions	Material v0 by owner	Owner edits title 3 times → GET /materials/{id}/revisions	"v1", "v2", "v3"	versionNo 1, 2, 3; listed newest first; each holds the state before that edit		Not run
TC-MAT-27	FR-015	Integration	Non-owner cannot view revisions (negative)	Material owned by A with 1 revision	B and then admin call GET /materials/{id}/revisions	—	B 403; admin 200		Not run
TC-MAT-28	FR-015, FR-018	Integration	File replacement keeps old file in revision	Material with file f1.pdf	Owner PATCH with new file f2.pdf	Valid 1 MB PDF	200; revision holds old fileUrl (f1); download returns f2		Not run
TC-MAT-29	FR-013	Integration	Restrict visibility again	Public material; B in sharedWith	Owner sets private, then shared with [] → B and C fetch	—	C 404 after private; B 404 after removal from sharedWith		Not run
TC-MOD-01	FR-016	Integration	Report hides material	Public material; student logged in	POST /materials/{id}/reports	reason "copyright"	201 status open; material missing from search for others; second open report by same user → 409		Not run
TC-MOD-02	FR-017	Integration	Admin dismisses report	Open report	PATCH /admin/reports/{id} {"decision":"dismiss"}	—	status dismissed; reviewerId = admin; material visible again		Not run
TC-MOD-03	FR-017	Integration	Admin upholds report	Open report	PATCH /admin/reports/{id} {"decision":"uphold"}	—	status actioned; material stays hidden		Not run
TC-MOD-04	FR-017, SEC-003	Integration	Non-admin cannot review (negative)	Educator token	PATCH /admin/reports/{id}	dismiss	403; report still open		Not run
TC-MOD-05	FR-016	Integration	Missing or invalid reason (negative)	Public material; student logged in	POST /materials/{id}/reports twice	no reason; reason "boring"	Both 400 VALIDATION_ERROR; no report; material still visible		Not run
TC-MOD-06	FR-016	Integration	Contributor and educator can report	Public material	Contributor, then educator, POST a report	reason "spam"	201 for both; two open reports stored		Not run
TC-MOD-07	FR-016	Integration	Admin cannot report (negative)	Admin logged in	POST /materials/{id}/reports	reason "spam"	403 FORBIDDEN; no report		Not run
TC-MOD-08	FR-016	Integration	Report unknown or private material (negative)	Private material owned by A	B reports a random ID, then A's private item	reason "copyright"	404 for both; no report		Not run
TC-MOD-09	FR-016	Integration	Can report again after review	Report by S dismissed	S reports the same material again	reason "copyright"	201 (one-open-report rule only blocks open reports)		Not run
TC-MOD-10	FR-016	Integration	Report rate limit (negative)	Student; many public materials	Submit reports quickly past the configured limit	Limit + 1 reports	Over the limit → 429 RATE_LIMITED; earlier reports stored		Not run
TC-MOD-11	FR-016	System	Report from the UI	Public material; students S1, S2	S1 clicks Report → reason + note → submit; S2 opens Library	reason "copyright"	S1 sees confirmation; material absent from S2's Library		Not run
TC-MOD-12	FR-017	Integration	Review queue oldest first	3 open reports, 1 dismissed	GET /admin/reports? status=open	—	Only the 3 open reports, oldest first, each with material title and reason		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-MOD-13	FR-017	Integration	Invalid decision or report ID (negative)	Admin; open report	PATCH /admin/reports/{id}	{"decision":"delete"}; random ID	400 VALIDATION_ERROR; 404 NOT_FOUND; report still open		Not run
TC-MOD-14	FR-017	Integration	Student cannot see review queue (negative)	Student token	GET /admin/reports?status=open	—	403 FORBIDDEN		Not run
TC-MOD-15	FR-017	Integration	Report decision is audited	Open report	Admin dismisses → check logs	—	Audit log entry with reportId, decision and admin userId		Not run
TC-MOD-16	FR-017	System (E2E)	Admin review in the console	Open report on material M	Admin Console → Reports → Dismiss; student opens Library	—	Report leaves the queue; M visible to the student again		Not run
TC-QZ-01	FR-020, FR-021	Integration	Create quiz with MCQ and T/F	Educator logged in	POST /quizzes	1 MCQ (4 options, key 1) + 1 T/F (key true); topic dbms	201; status draft; 2 questions saved		Not run
TC-QZ-02	FR-022	Unit (BVA)	MCQ option count boundaries	—	Validate questions	options 1, 2, 6, 7	1 and 7 → invalid; 2 and 6 → valid		Not run
TC-QZ-03	FR-021, FR-022	Unit	Bad answer key or unsupported type (negative)	—	Validate questions	MCQ no key; key 5 with 4 options; T/F key "yes"; type "essay"	All invalid with reason (400 VALIDATION_ERROR)		Not run
TC-QZ-04	FR-025	Integration	Publish gate blocks empty quiz	Draft quiz with 0 questions	POST /quizzes/{id}/publish	—	422 QUIZ_NOT_PUBLISHABLE; still draft		Not run
TC-QZ-05	FR-023, BR-3	System	Publish, then unpublish	Valid draft quiz	Publish → student opens → unpublish → student submits	—	Published visible; after unpublish submit → 404 QUIZ_NOT_AVAILABLE		Not run
TC-QZ-06	FR-023, BR-1, SEC-007	Integration	Non-author cannot edit / publish (negative)	Quiz by educator E1; contributor C1	C1 sends PUT and publish	—	403 for both; admin → 200		Not run
TC-QZ-07	FR-024	Integration	Topic linkage	2 published dbms quizzes, 1 os quiz	GET /quizzes?topic=DBMS; open a dbms material page	—	Exactly the 2 dbms quizzes (case-insensitive) on both		Not run
TC-QZ-08	FR-020	Integration	Contributor creates a quiz	Student with contributor = true logged in	POST /quizzes	title "DBMS Basics"; topic dbms; 1 T/F question (key true)	201; status draft; authorId = contributor		Not run
TC-LB-01	FR-035	Integration	Rank ties and best score	Students A, B, C with attempts	GET /leaderboard?quizId=...	A: 5 then 8; B: 8; C: 6 (max 10)	A rank 1 (8), B rank 1 (8), C rank 3 (6)		Not run
TC-LB-02	FR-035	Integration	Topic leaderboard	2 published quizzes in topic dbms	GET /leaderboard?topic=dbms	A: 80 %, 60 %; B: 100 % on one quiz	A 140 → rank 1; B 100 → rank 2		Not run
TC-LB-03	FR-035	Integration	Unpublished quiz excluded from topic leaderboard	Topic dbms: Q1 published, Q2 unpublished after attempts	GET /leaderboard?topic=dbms	A: Q1 50 %, Q2 100 %	A ranking score 50 (Q2 ignored)		Not run
TC-LB-04	FR-035	Unit	Competition ranking	—	rank(scores)	[9, 7, 7, 7, 5]	Ranks [1, 2, 2, 2, 5]		Not run
TC-LB-05	FR-035	Integration	Quiz with no attempts	Published quiz, 0 attempts	GET /leaderboard?quizId=...	—	200 with empty list		Not run
TC-LB-06	FR-035	Integration	Missing or bad parameters (negative)	—	GET /leaderboard with no params; quizId "abc"; unknown quizId	—	400 VALIDATION_ERROR; 400; 404 NOT_FOUND		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-LB-07	FR-035, BR-2	Integration	Retake improves rank	allowRetake = true; A 4/10, B 6/10	A retakes and scores 9 → GET leaderboard	—	A rank 1 (9), B rank 2 (6)		Not run
TC-LB-08	FR-035	Integration	All roles can view; login required	Quiz with attempts	GET leaderboard as student, contributor, educator, admin and without token	—	Same list (200) for all four roles; no token → 401		Not run
TC-LB-09	FR-035	System	Leaderboard in the UI	Quiz and topic with attempts	Open Leaderboard → switch quiz / topic	—	Ranked list with ties shown as 1, 1, 3; switching updates without reload		Not run
TC-ATT-01	FR-030	Integration	Student attempts published quiz	Published quiz, 3 questions	POST /quizzes/{id}/attempts	All answered	201 with attemptId, score, maxScore 3		Not run
TC-ATT-02	FR-030, BR-3	Integration	Draft quiz cannot be attempted (negative)	Draft quiz	POST attempt	—	404 QUIZ_NOT_AVAILABLE; no record		Not run
TC-ATT-03	FR-030, BR-2	Integration	Retake disabled	allowRetake = false; 1 attempt exists	Submit again (also 2 parallel first submits)	—	409 RETAKE_NOT_ALLOWED; parallel case stores exactly 1 attempt		Not run
TC-ATT-04	FR-031	Unit	Mixed answers scoring	—	score(questions, answers)	5 questions: 3 correct, 1 wrong, 1 missing	score 3, maxScore 5; isCorrect flags T,T,T,F,F		Not run
TC-ATT-05	FR-031	Unit (BVA)	All blank and all correct	—	score() twice	none answered; all correct	0 / 5 and 5 / 5		Not run
TC-ATT-06	FR-031, SEC-004	Integration	Invalid answers and client score (negative)	Published quiz	Submit unknown questionId; T/F response 3; include "score": 99	—	400 for invalid answers; with valid answers, stored score is server-computed (99 ignored)		Not run
TC-ATT-07	FR-032	System	Immediate feedback shown	Published quiz	Submit in UI	2 correct, 1 wrong	Result page without reload shows 2/3, per-question marks and correct answers		Not run
TC-ATT-08	FR-033	Integration	History and privacy	Student S1 has 3 attempts, S2 has 1	S1 GET /attempts/me; S1 GET /attempts/{S2 attempt}	—	3 items newest first with score, date; other student → 403		Not run
TC-ATT-09	FR-030	Integration	Educator / admin cannot attempt (negative)	Educator token	POST attempt	—	403 FORBIDDEN		Not run
TC-ATT-10	FR-033	Integration	Own attempt detail	Student has 1 attempt	GET /attempts/{id}	—	200 with answers, isCorrect per question, score, maxScore, submittedAt		Not run
TC-ATT-11	FR-033	Integration	Empty history	New student, no attempts	GET /attempts/me	—	200 with empty list; UI shows "No attempts yet"		Not run
TC-ATT-12	FR-033	Integration	History stable after quiz edit	Attempt scored 2/3	Author changes an answer key → student GET /attempts/me	—	Attempt still shows 2/3 (stored result, SAD D-3)		Not run
TC-ANL-01	FR-034	Integration	Progress by topic uses best score	Topic dbms: quiz Q1 attempts 40 %, 80 %; Q2 60 %	GET /analytics/me/progress	—	dbms: quizzesAttempted 2, averageBestPct 70; timeline has 3 points		Not run
TC-ANL-02	FR-034	Integration	Dashboard with no attempts	New student	GET /analytics/me/progress	—	200; topics [] and timeline []		Not run
TC-ANL-03	FR-034	Integration	Several topics	dbms: Q1 80 %; os: Q3 50 % then 100 %	GET /analytics/me/progress	—	dbms: 1 quiz, average 80; os: 1 quiz, average 100		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-ANL-04	FR-034	Integration	Own data only; educator blocked (negative)	S1 and S2 have attempts	S1 GET progress; educator GET progress	—	S1 sees only own attempts; educator 403		Not run
TC-ANL-05	FR-034	Unit	Percentage rounding and timeline order	—	progress(attempts)	Best 2/3 and 1/3 in one topic; 3 attempts on different days	averageBestPct 50.0; timeline sorted by submittedAt		Not run
TC-ANL-06	FR-034	System	Dashboard updates after an attempt	Student with 1 attempt	Attempt another quiz in UI → open My Progress	—	New point on the timeline; topic average updated		Not run
TC-PERF-01	NFR-001	Performance	Response time under load	Staging stack, seeded data	k6: 100 VUs, 10 min, mix browse/search/attempt	100 VUs	p95 page ≤ 3 s; p95 POST attempt ≤ 2 s		Not run
TC-PERF-02	NFR-002	Performance	100 concurrent users without errors	Same run as TC-PERF-01	Check k6 thresholds	—	0 % 5xx; 100 % checks pass		Not run
TC-AVL-01	NFR-003	System	Availability over 24-h evaluation window	Deployed demo stack	Uptime probe on /health every 30 s for 24 h	2,880 probes	≥ 2,852 successful probes (≥ 99 %)		Not run
TC-UX-01	NFR-004	Acceptance	First-time users complete a quiz	5 users new to the app	Task: log in, find dbms quiz, attempt, read result	Script + observer	≥ 4 of 5 succeed unaided; inline errors on all forms		Not run
TC-MNT-01	NFR-005	Static / Unit	Quality gate and coverage	CI pipeline	Run Sonar scan and jest --coverage	—	Gate passed; 0 blocker/critical; line coverage ≥ 70 % on core services		Not run
TC-PORT-01	NFR-006	System (E2E)	Cross-browser smoke	Staging	Playwright login → search → attempt; then manual smoke on real Safari	Chrome and Edge (branded channels), Firefox, WebKit; Safari on macOS/iOS if available	All automated runs pass; Safari smoke passes, or is recorded as not available with WebKit as proxy		Not run
TC-REL-01	NFR-007	Reliability	Attempt survives restart; no loss under concurrency	Staging	Submit → get 201 → restart api container → query; 100 parallel submits by 100 students	—	Attempt present after restart; exactly 100 records		Not run
TC-TST-01	NFR-008	Unit	Services run without UI or real DB	CI agent	npm test in server/ (mocks, in-memory MongoDB)	—	Suite passes headless with no browser and no external DB		Not run
TC-SEC-01	SEC-001	Security	Passwords hashed, never logged	User registered with known pwd	Inspect users collection; grep logs	"Passw0rd"	\$2b\$12\$ hash; password string absent from all logs		Not run
TC-SEC-02	SEC-002	Security	Expired / tampered / missing JWT	Valid token available	Call GET /users/me with expired, signature-modified, alg "none" and no token	—	401 for every case		Not run
TC-SEC-03	SEC-003	Security	RBAC matrix	4 accounts (one per class)	Automated role × endpoint table (SAD §3.9.2)	~40 combinations	Every result matches the matrix (200/201 or 403)		Not run
TC-SEC-04	SEC-004, FR-014	Security	NoSQL injection and XSS	—	Login with operator payload; comment with script tag; render page	{"email":"{\$gt":""}"; <script>alert(1)</script>	400 for injection; comment shown as text, no script runs		Not run
TC-SEC-05	SEC-005	Security	TLS configuration	Deployed stack	curl http://; testssl.sh / ssllscan	TLS 1.0, 1.1, 1.2, 1.3	HTTP → 301 HTTPS; only TLS 1.2/1.3 accepted; HSTS header present		Not run
TC-SEC-06	SEC-006, FR-010	Security (BVA)	Upload type and size	Contributor	Upload test files	20 MB PDF; 20 MB + 1 B PDF; .exe renamed .pdf; .svg	201; 413; 415; 415		Not run

TC ID	Req	Level / Type	Description	Pre-condition	Steps	Test data	Expected result	Actual	Status
TC-SEC-07	SEC-007	Security	IDOR on material and quiz	A owns M1 and Q1; B is a contributor	B sends PATCH/DELETE M1 and PUT/DELETE Q1	—	403 on all four; data unchanged		Not run
TC-SEC-08	SEC-008	Security	Answer keys not exposed	Published quiz; student token	GET /quizzes/{id}; inspect full JSON and network tab before submit	—	No answerKey / correctAnswer anywhere before submission		Not run

13.2 Requirements → test cases traceability (RTM)

Table STP-2: Requirement coverage (N = not yet executed, P = partially passed, A = all passed)

Req ID	Test case(s)	Owner	Status	Req ID	Test case(s)	Owner	Status
FR-001	TC-AUTH-01, TC-AUTH-02, TC-AUTH-03	Anisha	N	FR-030	TC-ATT-01, TC-ATT-02, TC-ATT-03, TC-ATT-09	Bharat	N
FR-002	TC-AUTH-04, TC-AUTH-05, TC-AUTH-12, TC-AUTH-13	Anisha	N	FR-031	TC-ATT-04, TC-ATT-05, TC-ATT-06	Bharat	N
FR-003	TC-AUTH-06	Anisha	N	FR-032	TC-ATT-07	Bharat	N
FR-004	TC-AUTH-07, TC-AUTH-08, TC-AUTH-11, TC-AUTH-21, TC-AUTH-22, TC-AUTH-23, TC-AUTH-24, TC-AUTH-25	Anisha	N	FR-033	TC-ATT-08, TC-ATT-10, TC-ATT-11, TC-ATT-12	Bharat	N
FR-005	TC-AUTH-09, TC-AUTH-14, TC-AUTH-15, TC-AUTH-16, TC-AUTH-17, TC-AUTH-18, TC-AUTH-19, TC-AUTH-20	Anisha	N	FR-034	TC-ANL-01, TC-ANL-02, TC-ANL-03, TC-ANL-04, TC-ANL-05, TC-ANL-06	Bharat	N
FR-006	TC-AUTH-10	Anisha	N	NFR-001	TC-PERF-01	All	N
FR-010	TC-MAT-01, TC-MAT-02, TC-MAT-03, TC-MAT-09, TC-MAT-10, TC-MAT-12, TC-SEC-06	Aryaroop	N	NFR-002	TC-PERF-02	All	N
FR-011	TC-MAT-01, TC-MAT-11	Aryaroop	N	NFR-003	TC-AVL-01	All	N
FR-012	TC-MAT-04, TC-MAT-13, TC-MAT-14, TC-MAT-15, TC-MAT-16, TC-MAT-18, TC-MAT-19	Aryaroop	N	NFR-004	TC-UX-01	All	N
FR-013	TC-MAT-05, TC-MAT-17, TC-MAT-18, TC-MAT-23, TC-MAT-29	Aryaroop	N	NFR-005	TC-MNT-01	All	N
FR-014	TC-MAT-06, TC-MAT-20, TC-MAT-21, TC-MAT-22, TC-MAT-23, TC-MAT-24, TC-MAT-25, TC-SEC-04	Aryaroop	N	NFR-006	TC-PORT-01	All	N
FR-015	TC-MAT-07, TC-MAT-26, TC-MAT-27, TC-MAT-28	Aryaroop	N	NFR-007	TC-REL-01	All	N
FR-016	TC-MOD-01, TC-MOD-05, TC-MOD-06, TC-MOD-07, TC-MOD-08, TC-MOD-09, TC-MOD-10, TC-MOD-11	Aryaroop	N	NFR-008	TC-TST-01	All	N
FR-017	TC-MOD-02, TC-MOD-03, TC-MOD-04, TC-MOD-12, TC-MOD-13, TC-MOD-14, TC-MOD-15, TC-MOD-16	Aryaroop	N	SEC-001	TC-SEC-01	All	N
FR-018	TC-MAT-07, TC-MAT-08, TC-MAT-28	Aryaroop	N	SEC-002	TC-AUTH-06, TC-SEC-02	All	N
FR-020	TC-QZ-01, TC-QZ-08	Ayush	N	SEC-003	TC-AUTH-07, TC-MOD-04, TC-SEC-03	All	N
FR-021	TC-QZ-01, TC-QZ-03	Ayush	N	SEC-004	TC-ATT-06, TC-SEC-04	All	N
FR-022	TC-QZ-02, TC-QZ-03	Ayush	N	SEC-005	TC-SEC-05	All	N
FR-023	TC-QZ-05, TC-QZ-06	Ayush	N	SEC-006	TC-SEC-06	All	N

Req ID	Test case(s)	Owner	Status	Req ID	Test case(s)	Owner	Status
FR-024	TC-QZ-07	Ayush	N	SEC-007	TC-MAT-08, TC-QZ-06, TC-SEC-07	All	N
FR-025	TC-QZ-04	Ayush	N	SEC-008	TC-SEC-08	All	N
FR-035	TC-LB-01, TC-LB-02, TC-LB-03, TC-LB-04, TC-LB-05, TC-LB-06, TC-LB-07, TC-LB-08, TC-LB-09	Ayush	N				

13.3 Test cases per use case

As required by the course test-plan guideline, every implemented use case has **at least 8 test cases** across unit, integration and system levels (counted from the Req column of §13.1; a test case can support more than one use case):

Table STP-3: Test cases per use case

UC	Use case	FRs	Test cases	Unit	Integration	System / other
UC-01	Register / log in / reset password	FR-001, FR-002, FR-003, FR-006	13	1	8	4
UC-02	Manage profile	FR-005	9	1	6	2
UC-03	Upload study material	FR-010, FR-011	8	2	5	1
UC-04	Search & browse material	FR-012, FR-013	11	0	10	1
UC-05a	Rate & comment	FR-014	8	2	4	2
UC-05b	Organise & share material	FR-013, FR-015, FR-018	10	0	10	0
UC-06	Create & manage quiz	FR-020, FR-021, FR-022, FR-023, FR-024, FR-025	8	2	5	1
UC-07	Attempt quiz	FR-030, FR-031, FR-032	8	2	5	1
UC-08	View results & progress	FR-033, FR-034	10	1	8	1
UC-09	View leaderboard	FR-035	9	1	7	1
UC-10a	Assign role / contributor	FR-004	9	0	6	3
UC-10b	Review reported material	FR-017	8	0	7	1
UC-11	Report study material	FR-016	8	0	7	1

14. Test Metrics & Reporting

- % of test cases executed and % passed / failed (per module and per level).
- Requirement coverage: % of SRS requirements with all linked tests passed (target 100 % before release).
- Unit-test line and branch coverage per core module (target ≥ 70 % lines, NFR-005).
- Defect density (defects per module / KLOC), defect aging, and open defects by severity.
- Performance results: p95 latency and error rate against NFR-001 / NFR-002.

Reports: CI dashboard on every build; a short test status update in each sprint review; the final Test Summary Report with the completed RTM.

15. Approvals

Role	Name	Signature / Date
QA Lead	Bharat V Bhat	
Dev Lead / API reviewer	Anisha Nukul Niranjana	
Product Owner (Course Faculty)	Dr Sapna V M	